

CEHv3 note

Content

CEHv13 Tool List.....	2
1 Cloud Computing.....	10
2 Cryptography	14
3 Information Security and Ethical Hacking Overview	25
4 Mobile Platform, IoT, and OT Hacking.....	38
5 Network and Perimeter Hacking.....	47
6 Reconnaissance Techniques	89
7 System Hacking Phases and Attack Techniques	113
8 Web Application Hacking.....	122
9 Wireless Network Hacking.....	132

Section Name	Total Score
Cloud Computing	7
Cryptography	7
Information Security and Ethical Hacking Overview	8
Mobile Platform, IoT, and OT Hacking	10
Network and Perimeter Hacking	18
Reconnaissance Techniques	26
System Hacking Phases and Attack Techniques	21
Web Application Hacking	20
Wireless Network Hacking	8

CEHv13 Tool List

Sniffers

- Wireshark: The most popular packet sniffer with cross platform support.
- Tcpdump: A popular CLI sniffer available for both the Unix and Linux platforms. tcpdump -i eth0 # Capture on eth0 tcpdump -w cap.log # Write to cap.log tcpdump -r cap.log (Read from cap.log)
- Windump: Windows version of tcpdump.
- Cain & Abel: It's an all-in-one tool to capture packets and record passwords being used in a MiTM. It can create an ARP and DNS poisoning events, and the cracker works with methods such as network packet sniffing, dictionary, brute force and cryptanalysis such as rainbow attacks.
- Kismet: Wireless sniffing tool used to locate and discover hidden SSID's. It can be used to passively sniff the traffic and gain the password that way.
- Ntop: High speed web-based traffic analysis.
- Network Miner: Packet sniffer, with built in OS finger printer. Drop down the navigator to filter specific traffic. Automatically extracts files for packet capture; it will also extract images. It will also pull some credentials for specific sites. It can also filter out "keywords" to allow for filtering of specific information being sent across the network.

Scanners

- Nmap: uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics.
 - nmap -T4 -n -sS 192.168.0.1/24 # SYN

- Study -sT (tcp), -sS (syn), -sA (ack), -sF (fin), -sN (null), -sX (xmas), -sI (idle), -sU (udp), -sV (service detection), -O (OS detection)
- -sA: ACK Filtered/Unfiltered For detecting firewall, unfiltered (open/close) returns
- RST packet
- -sF: FIN Closed/Open|Filtered RST when closed, no response when open|filtered
- -sX: XMAS FIN, PSH, URG Same as FIN
- -sN: NULL Same as FIN
- -sU: UDP Open/Closed/Filtered/Open|Filtered UDP response when open, ICMP type
- 3 code 3 (Port Unreachable) when closed, other ICMP when filtered, no response
- when open|filtered
- -sI: host:port: IDLE Stealth scan using zombie host and IP fragmentation ID
- Zenmap: Nmap with a GUI and ability to plot a map for reference.
- Angry IP Scanner: (or simply ipscan) is an open-source and cross-platform network scanner designed to be fast and simple to use. It scans IP addresses and ports as well as has many other features.
- hping2 & 3: Custom packet-crafting tool that can be used to precisely package packets to scan and penetrate networks and bypass known security features.
- hping3 -c 3 --scan 1-3000 -S -V 192.168.1.254 # Scans port 1-3000 on 192.168.1.254 with 3 SYN packets each hping3 -c 100 -d 120 -S -p 21 --flood --rand- source google.com # Flood google with 100 counts, SYN packets with data size 120 bytes, on port 21, with random spoofed IP source
- SuperScan: allows you to quickly scan a range of IP addresses and do TCP port scanning. It can check all ports, or the ones you select. It is a very fast and powerful tool. Supports banner grabbing, ping, whois, tracert. Recently bought by McAfee.

- Zanti (mobile): An Android software used for Scan Ports, MiTM, Session Hijack, Redirect URL traffic, used for Pentesting with a noble device.
- NBTScan: It sends a NetBIOS status query to each address in a supplied range and lists received information in human readable form. For each responded host it lists IP address, NetBIOS computer name, logged-in username and MAC address. SUPER FAST SCANS
- NetScan Tools: Created in 1999 to automate the plethora of internet tools to work with one GUI supported by Windows platforms. OS Fingerprinting, Packet sniffing, port scanning, packet flooding, mail exchange validation.
- Nessus: Vulnerability scanners that is used by pentesters, hackers, and enterprise security engineers.

Enumeration

- DumpSec: Reveals users, groups, printers, shares, registry info in an easy to digest human readable format from a targeted system. Very useful for finding out intimate information about the specific system for privilege escalation purposes.
- SuperScan: Also used for enumeration. *See Scanning
- Netcat: A simple tool that can read and write data across a TCP or UDP connection. It's very useful because it can create almost any type of connection. Including session binding. It allows actors to create shell and reverse shell connections between two endpoints. Allowing them to send / receive files and execute commands on both the host and compromised systems. It has since lost support; consequently, the Nmap project has incorporated an upgraded version called Ncat. Other remakes: Socat, OpenBSD's nc, Cryptcat, netcat6, pnetcat, etc.
- `nc -zv -w 1 google.com 21 # Scan google's port 21, -z scan, -v verbose, -w timeout`
`nc -lvp 6969 # Opens a server on 6969, -l listens, -v verbose, -p port 6969`
`nc 192.168.1.54 6969`

Banner Grab with GET / HTTP/1.1 after connecting CRYPTCAT, netcat alternative with encryption involved

- Cryptcat: A variant of netcat that encrypts communication; making it useful to evade the detection of IDS or traffic sniffing.
- TCPView: It will enumerate all TCP and UDP connections on the end point running the application. Will resolve domain names for the IP's connected to the system. Monitors changing connections and can close existing connections. SKILLCERTPRO PREMIUM CONTENT: UNAUTHORISED DISTRIBUTION IS PROHIBITED
- Sysinternals Suite: A suite of sysinternal tools made by Microsoft for troubleshooting. NirSoft Suite: A suite of tools used to automate the troubleshooting of Windows.
- Firewall: An active reconnaissance network security tool that attempts to determine what layer 4 protocols a given IP forwarding device will pass. It works by sending out TCP or UDP packets with a TTL one greater than the targeted gateway.
- firewall -S1-1000 -i eth0 -n -pTCP 192.168.1.254 192.168.1.30 # Scan port 1- 1000 through eth0, no hostname resolution, with TCP protocol, via gateway 192.168.1.254 against target 192.168.1.30
- nslookup: A network administration command-line tool available in many computers operating systems for querying the Domain Name System to obtain domain name or IP address mapping, or other DNS records.
- Nslookup - server ns1.google.com set type=any # Or A (address), NS (nameserver), MX (mailserver), SOA (start of authority), CNAME (canonical name), PTR (pointer) ls -d google.com # Zone transfer
- DIG: A network administration command-line tool for querying the Domain Name System. dig is useful for network troubleshooting and for educational purposes. It can operate based on command line option and flag arguments, or in batch mode by reading requests from an operating system file.

- NBTSTAT: A diagnostic tool for NetBIOS over TCP/IP. It is included in several versions of Microsoft Windows. Its primary design is to help troubleshoot NetBIOS name resolution problems.
- `nbtstat -A 192.168.1.254 # Get remote NetBIOS table` `nbtstat -n # Get local table`
- WHOIS: Searches for an object in a WHOIS database. WHOIS is a query and response protocol that is widely used for querying databases that store the registered users of an Internet resource, such as a domain name or an IP address block, but is also used for a wider range of other information.
 - `whois google.com` Important WHOIS Registrars:
 - ARIN - North America
 - APNIC - Asia Pacific
 - AFRINIC - Africa
 - LACNIC - Latin America and Caribbean RIPE - Europe
- Maltego: An interactive data mining tool that renders directed graphs for link analysis. The tool is used in online investigations for finding relationships between pieces of information from various sources located on the Internet.
- `sc query`: Obtains and displays information about the specified service, driver, type of service, or type of driver.

Password Cracking Tools

- L0phtCrack: A password cracking application used for locally or remotely locating user account information and cracking the corresponding passwords. Windows/Unix/Linux/FreeBSD/ etc. Can be used for periodically scanning and cracking system passwords.
- Ophcrack: Free version of Ophcrack. Less features. Not as robust.

- Medusa: Remote, speedy, modular brute force cracker for network services (HTTP, MySQL, SMB, SMTP, SNMP, SSHv2).
- Trinity Rescue Kit: Live Linux distribution that aims specifically at recovery and repair operations on Windows machines but is equally usable for Linux recovery issues. Since version 3.4 it has an easy-to-use scrollable text menu that allows anyone who master's a keyboard and some English to perform maintenance and repair on a computer, ranging from password resetting over disk cleanup to virus scanning.
- John the Ripper: CLI password cracking utility that can have custom rules created as well as use custom password lists to crack passwords.
 - `john shadow.txt john --wordlist=passwords.txt shadow.txt`
- RainbowCrack: Cracks hashes referenced against rainbow tables. It's different from traditional brute force crackers in that it uses large pre-computed tables called "rainbow tables"; which reduces the amount of time the brute force takes.
- Brutus: Older remote password cracker.

Wireless Tools

- Kismet: A sniffing tool and a multi-purpose wireless tool. It can be used for IDS and many other things.
- inSSIDer: Used to monitor local WiFi traffic and identify the channels different networks are communicating on. It was originally designed for optimizing Office / Home network WAP placement to reduce interference and produce the most optimal signals for the environment.
- Reaver: WPS brute forcing tool. This tool waits to intercept the WPS beacon; once it's captured it will brute force the WPS PIN and the PSK password.
- Netstumbler (Old but useful on 32bit systems): Like inSSIDer, but not as feature rich.

- Bluesnarfer: A tool used to steal information from a mobile device through the bluetooth connection.
- Aircrack-ng: Is a tool suite used to assess WiFi security. It focuses on monitoring, attacking, testing and cracking a WAP. It can capture and analyze packets; create replay attacks, deauthentication with injection techniques; test WiFi cards and their driver capabilities; and crack WEP and WPA PSK
- Airmon-ng (Aircrack): Aircrack's sniffing tool.
- Airodump-ng (Aircrack): Used to capture 802.11 packets, especially good at capturing WEP IV's to be used with Aircrack-ng. It can also be used to log the GPS coordinates of found WAP's if a GPS receiver is connected to your device.

Logging and Event Viewing Tools

- Log Parser Lizard: A Microsoft based log viewing tool that presents information in a GUI based format. It's capable of presenting data from individual systems, SQL servers, AD, IIS, and many other types of log/events creating applications or systems.
- Splunk: An enterprise tool used to store and parse logs on a large scale to monitor network activity and functionality.
- SolarWinds: An enterprise tool like Splunk, with the exception that it can create a database for network monitoring. It's useful in visualizing the configuration of the network in a live environment which reduces the need for static network topology tools like Vizio.

Other Tools

- Snort: A freeware IDS / IPS.

- Metasploit: This is an automated framework capable of exploiting vulnerabilities with many tools across many platforms.

Hardware Tools

- Minipwner: A small device that can be connected to the target network and left behind to allow the actor to gather information remotely. It can be configured with a battery or power cord. It's low power consumption allows the device to use a WAP on battery power for several hours.
- USB Rubber Ducky: A flash drive that is recognized as a Human Interface Device (HID). It can bypass most enterprise DLP software since the software thinks the device is a keyboard. It can run scripts and gather data among many other uses that can be dreamt up for it.
- Wi-Fi Pineapple: A small discrete device that has powerful application for pentesting. It can be used as a potential Evil Twin WAP. It comes with an impressive suite of applications that helps to analyze the data collected by the device.
- LAN Turtle: A Small USB-to-Ethernet adapter that can be placed on a victim's computer inside the target network. I can fingerprint and enumerate the network and be used to create an SSH into the network. It can also spoof DNS entries on the network for a redirection / session hijacking attack.
- AirPcap: A USB designed to provide a hardware based pentesting tool. It works in conjunction with other common tools. It can be used on wireless networks and may conduct packet injections to active connections. It can function as an Evil Twin, or Rogue AP.
- Ubertooth One: A USB device that can be used to scan for Bluetooth communication

1 Cloud Computing

Number of Questions – 7

Description:

- Cloud Computing Concepts
- Container Technology
- Serverless Computing
- Cloud Computing Threats
- Cloud Hacking
- Cloud Security

Cloud Computing Basics

Infrastructure as a Service (IaaS)

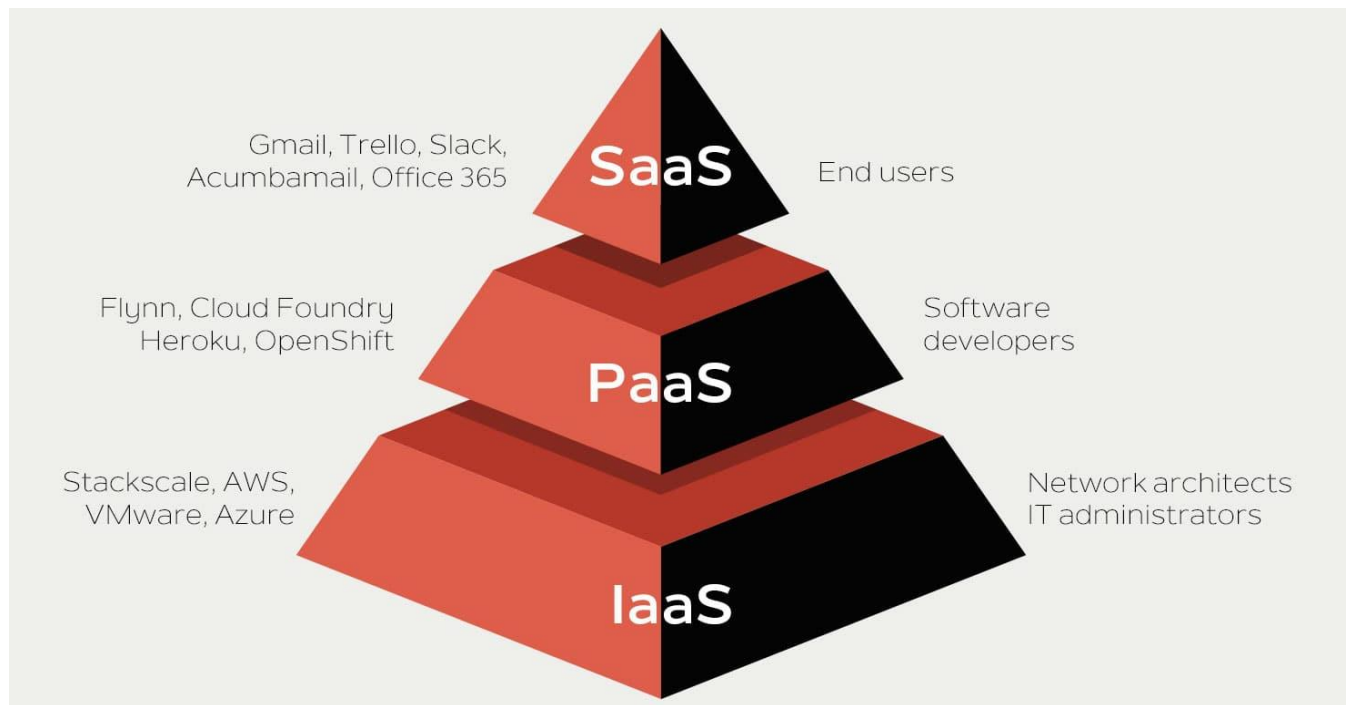
- Provides virtualized computing resources
- Third party hosts the servers with hypervisor running the VMs as guests
- Subscribers usually pay on a per-use basis

Platform as a Service (PaaS)

- Geared towards software development
- Hardware and software hosted by provider
- Provides ability to develop without having to worry about hardware or software

Software as a Service (SaaS)

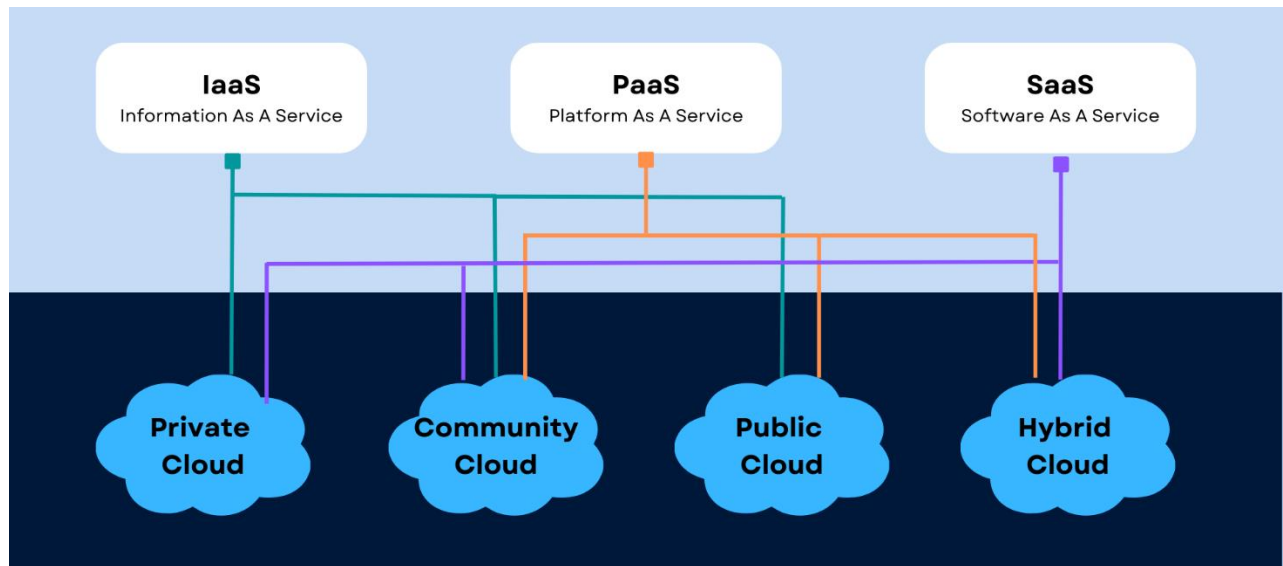
- Provider supplies on-demand applications to subscribers
- Offloads the need for patch management, compatibility and version control



Deployment Models

- Public Cloud - services provided over a network that is open for public to use
- Private Cloud - cloud solely for use by one tenant; usually done in larger organizations
- Community Cloud - cloud shared by several organizations, but not open to public
- Hybrid Cloud - a composition of two or more cloud deployment models
- NIST Cloud Architecture
 - Cloud Carrier - organization with responsibility of transferring data; akin to power distributor for electric grid
 - Cloud Consumer - acquires and uses cloud products and services
 - Cloud Provider - purveyor of products and services
 - Cloud Broker - manages use, performance and delivery of services as well as relationships between providers and subscribers
 - Cloud Auditor - independent assessor of cloud service and security controls
- FedRAMP - regulatory effort regarding cloud computing

- PCI DSS - deals with debit and credit cards, but also has a cloud SIG



Cloud Security

- Problem with cloud security is what you are allowed to test and what should you test
- Another concern is with a hypervisor, if the hypervisor is compromised, all hosts on that hypervisor are as well
- Trusted Computing Model - attempts to resolve computer security problems through hardware enhancements
 - Roots of Trust (RoT) - set of functions within TCM that are always trusted by the OS
- Tools:
 - CloudInspect - pen-testing application for AWS EC2 users
 - CloudPassage Halo instant visibility and continuous protection for servers in any cloud
 - Dell Cloud Manager
 - Qualys Cloud Suite

- Trend Micro's Instant-On Cloud Security
- Panda Cloud Office Protection

Threats and Attacks

- Data Breach or Loss - biggest threat; includes malicious theft, erasure or modification
- Shadow IT - IT systems or solutions that are developed to handle an issue but aren't taken through proper approval chain
- Abuse of Cloud Resources - another high threat (usually applies to IaaS and PaaS)
- Insecure Interfaces and APIs - cloud services can't function without them, but need to make sure they are secure
- Service Oriented Architecture - API that makes it easier for application components to cooperate and exchange information
- Insufficient due diligence - moving an application without knowing the security differences
- Shared technology issues - multitenant environments that don't provide proper isolation
- Unknown risk profiles - subscribers simply don't know what security provisions are made in the background
- Others include malicious insiders, inadequate design and DDoS
- Wrapping Attack - SOAP message intercepted and data in envelope is changed and sent/replayed
- Session riding - CSRF under a different name; deals with cloud services instead of traditional data centers
- Side Channel Attack - using an existing VM on the same physical host to attack another
- This is more broadly defined as using something other than the direct interface to attack a system

2 Cryptography

Number of Questions – 7

Description:

- Cryptography Concepts
- Encryption Algorithms
- Cryptography Tools
- Public Key Infrastructure (PKI)
- Email Encryption
- Disk Encryption
- Cryptanalysis
- Cryptography Attack Countermeasures

Cryptograph Basics

- Cryptography - science or study of protecting information whether in transit or at rest
 - Renders the information unusable to anyone who can't decrypt it
 - Takes plain text, applies cryptographic method, turn it into cipher text
- Crypanalysis - study and methods used to crack cipher text
- Linear Cryptanalysis - works best on block ciphers
- Differential Cryptanalysis - applies to symmetric key algorithms
 - Compares differences in the inputs to how each one affects the outcome
- Integral cryptanalysis - input vs output comparison same as differential; however, runs multiple computations of the same block size input
- Plain text doesn't necessarily mean ASCII format - it simply means unencrypted data

- Nonrepudiation - means by which a recipient can ensure the identity of the sender and neither party can deny sending

Encryption Algorithms and Techniques

- Algorithm - step-by-step method of solving a problem
- Two General Forms of Cryptography
 - Substitution - bits are replaced by other bits
 - Transposition - doesn't replace; simply changes order
- Encryption Algorithms - mathematical formulas used to encrypt and decrypt data
- Stream Cipher - readable bits are encrypted one at a time in a continuous stream
 - Usually done by an XOR operation
 - Work at a high rate of speed
- Block Cipher - data bits are split up into blocks and fed into the cipher
 - Each block of data (usually 64 bits) encrypted with key and algorithm
 - Are simpler and slower than stream ciphers
- XOR - exclusive or; if inputs are the same (0,0 or 1,1), function returns 0; if inputs are not the same (0,1 or 1,0), function returns 1
- Key chosen for cipher must have a length larger than the data; if not, it is vulnerable to frequency attacks

Symmetric Encryption

Symmetric encryption (secret-key, shared-key, and private-key) uses the same key for encryption as it does for decryption



Asymmetric Encryption

Asymmetric encryption (public-key) uses different encryption keys, which are called public and private keys for encryption and decryption, respectively



Symmetric Encryption

- Symmetric Encryption - known as single key or shared key
 - One key is used to encrypt and decrypt the data
 - Problems include key distribution and management
 - Suitable for large amounts of data
 - Harder for groups of people because more keys are needed as group increases
 - Does nothing for nonrepudiation; only performs confidentiality
- Algorithms
 - DES - block cipher; 56 bit key; quickly outdated and now considered not very secure

- 3DES - block cipher; 168 bit key; more effective than DES but much slower ○ AES (Advanced Encryption Standard) - block cipher; 128, 192 or 256 bit key; replaces DES; much faster than DES and 3DES
- IDEA (International Data Encryption Algorithm) - block cipher; 128 bit key; originally used in PGP 2.0
- Twofish - block cipher; up to 256 bit key ○ Blowfish - fast block cipher; replaced by AES; 64 bit block size; 32 to 448 bit key; considered public domain
- RC (Rivest Cipher) - RC2 to RC6; block cipher; variable key length up to 2040 bits
- RC6 (latest version) uses 128 bit blocks and 4 bit working registers; RC5 uses variable block sizes and 2 bit working registers

Asymmetric Encryption

- Uses two types of keys for encryption and decryption
- Public Key - generally used for encryption; can be sent to anyone
- Private Key - kept secret; used for decryption
- Comes down to what one key encrypts, the other decrypts
- The private key is used to digitally sign a message
- Algorithms
 - Diffie-Hellman - developed as a key exchange protocol; used in SSL and IPsec; if digital signatures are waived, vulnerable to MITM attacks
 - Elliptic Curve Cryptosystem (ECC) - uses points on elliptical curve along with logarithmic problems; uses less processing power; good for mobile devices
 - El Gamal - not based on prime number factoring; uses solving of discrete logarithm problems

- RSA - achieves strong encryption through the use of two large prime numbers; factoring these create key sizes up to 4096 bits; modern de facto standard
- Only downside is it's slower than symmetric especially on bulk encryption and processing power



Hash functions **calculate a unique fixed-size bit string** representation called a message digest of any arbitrary block of information

If any given bit of the function's input is changed, then every output bit has a **50 percent** chance of changing

It is computationally infeasible to have two files with the **same message digest value**

Hash Algorithms

- Hash - one-way mathematical function that produces a fix-length string (hash) based on the arrangement of data bits in the input
- Algorithms
 - MD5 (Message Digest algorithm) - produces 128 bit hash expressed as 32 digit hexadecimal number; has serious flaws; still used for file download verification
 - SHA-1 - developed by NSA; 160 bit value output
 - SHA-2 – four separate hash functions; produce outputs of 224, 256, 384 and 512 bits; not widely used
 - SHA-3 - uses sponge construction ○ RIPEMD-# -works through 80 stages, executing 5 blcask 16 times each; uses modulo 32 addition
- Collision - occurs when two or more files create the same output

- Can happen and can be used as an attack; rare, though
- DHUK Attack (Don't Use Hard-Coded Keys) - allows attackers to access keys in certain VPN implementations; affects devices using ANSI X9.31 with a hard-coded seed key
- Rainbow Tables - contain precomputed hashes to try and find out passwords
- Salt - used with a hash to obscure the hash; collection of random bits
- Things to Remember
 - Hashes are used for integrity
 - Hashes are one-way functions
- Tools
 - HashCalc
 - MD5 Calculator
 - HashMyFiles

PKI System

- Public Key Infrastructure (PKI) - structure designed to verify and authenticate the identity of individuals
- Registration Authority - verifies user identity
- Certificate Authority - third party to the organization; creates and issues digital certificates
- Certificate Revocation List (CRL) - used to track which certificates have problems and which have been revoked
- Validation Authority - used to validate certificates via Online Certificate Status Protocol (OCSP)
- Trust Model - how entities within an enterprise deal with keys, signatures and certificates

- Cross-Certification - allows a CA to trust another CS in a completely different PKI; allows both CAs to validate certificates from either side
- Single-authority system - CA at the top
- Hierarchical trust system - CA at the top (root CA); makes use of one or more RAs (subordinate CAs) underneath it to issue and manage certificates

Digital Certificates

- Certificate - electronic file that is used to verify a user's identity; provides nonrepudiation
- X.509 - standard used for digital certificates
- Contents of a Digital Certificate
 - Version - identifies certificate format
 - Serial Number - used to uniquely identify certificate
 - Subject - who or what is being identified
 - Algorithm ID (Signature Algorithm) - shows the algorithm that was used to create the certificate
 - Issuer - shows the entity that verifies authenticity
 - Valid From and Valid To - dates certificate is good for
 - Key Usage - what purpose the certificate serves
 - Subject's Public Key - copy of the subject's public key
 - Optional Fields - Issuer Unique Identifier, Subject Alternative Name, and Extensions
- Some root CAs are automatically added to OSES that they already trust; normally are reputable companies

- Self-Signed Certificates - certificates that are not signed by a CA; generally not used for public; used for development purposes
 - Signed by the same entity it certifies

Digital Signatures

- When signing a message, you sign it with your private key and the recipient decrypts the has with their public key
- Digital Signature Algorithm (DSA) - used in generation and verification of digital signatures per FIPS 186-2

Full Disk Encryption

- Data at Rest (DAR) - data that is in a stored state and not currently accessible
- Usually protected by full disk encryption (FDE) with pre-boot authentication o
- Example of FDE is Microsoft BitLocker and McAfee Endpoint Encryption
- FDE also gives protection against boot-n-root

Encrypted Communication

- Often-Used Encrypted Communication Methods
 - Secure Shell (SSH) - secured version of telnet; uses port 22; relies on public key cryptography; SSH2 is successor and includes SFTP
 - Secure Sockets Layer (SSL) - encrypts data at transport layer and above; uses RSA encryption and digital certificates; has a six-step process; largely has been replaced by TLS

- Transport Layer Security (TLS) - uses RSA 1024 and 2048 bits; successor to SSL; allows both client and server to authenticate to each other; TLS Record
- Protocol provides secured communication channel
 - Internet Protocol Security (IPSEC) - network layer tunnelling protocol; used in tunnel and transport modes; ESP encrypts each packet
 - PGP - Pretty Good Privacy; used for signing, compress and encryption of emails, files and directories; known as hybrid cryptosystem - features conventional and public key cryptography
 - S/MIME - standard for public key encryption and signing of MIME data; only difference between this and PGP is PGP can encrypt files and drives unless S/MIME
- Heartbleed - attack on OpenSSL heartbeat which verifies data was received correctly
 - Vulnerability is that a single byte of data gets 64kb from the server
 - This data is random; could include usernames, passwords, private keys, cookies; very easy to pull off
 - `nmap -d --script ssl-heartbleed --script-args vulns.showall -sV [host]`
 - Vulnerable versions include Open SSL 1.0.1 and 1.0.1f
 - CVE-2014-0160
- FREAK (Factoring Attack on RSA-EXPORT Keys) - man-in-the-middle attack that forces a downgrade of RSA key to a weaker length
- POODLE (Paddling Oracle On Downgraded Legacy Encryption) - downgrade attack that used the vulnerability that TLS downgrades to SSL if a connection cannot be made
 - SSL 3 uses RC4, which is easy to crack
 - CVE-2014-3566
 - Also called PoodleBleed
- DROWN (Decrypting RSA with Obsolete and Weakened eNcryption) - affects SSL and TLS services
 - Allows attackers to break the encryption and steal sensitive data

- Uses flaws in SSL v2
- Not only web servers; can be IMAP and POP servers as well

Cryptography Attacks

- Known plain-text attack - has both plain text and cipher-text; plain-text scanned for repeatable sequences which is compared to cipher text
- Chosen plain-text attack - attacker encrypts multiple plain-text copies in order to gain the key
- Adaptive chosen plain-text attack - attacker makes a series of interactive queries choosing subsequent plaintexts based on the information from the previous encryptions; idea is to glean more and more information about the full target cipher text and key
- Cipher-text-only attack - gains copies of several encrypted messages with the same algorithm; statistical analysis is then used to reveal eventually repeating code
- Replay attack
 - Usually performed within context of MITM attack
 - Hacker repeats a portion of cryptographic exchange in hopes of fooling the system to setup a communications channel
 - Doesn't know the actual data - just has to get timing right
- Chosen Cipher Attack
 - Chooses a particular cipher-text message
 - Attempts to discern the key through comparative analysis
 - RSA is particularly vulnerable to this
- Side-Channel Attack
 - Monitors environmental factors such as power consumption, timing and delay

- Tools
 - Carnivore and Magic Lantern - used by law enforcement for cracking codes
 - L0phtcrack - used mainly against Windows SAM files
 - John the Ripper - UNIX/Linux tool for the same purpose
 - PGPcrack - designed to go after PGP-encrypted systems
 - CrypTool
 - Cryptobench
 - Jipher
- Keys should still change on a regular basis even though they may be "unhackable"
- Per U.S. government, an algorithm using at least a 256-bit key cannot be cracked

How to Defend Against Cryptographic Attacks

1 Access to cryptographic keys should be given to the application or user directly	7 Message authentication must be implemented for encryption of symmetric-key protocols
2 Intrusion detection system should be deployed to monitor exchange and access of keys	8 For asymmetric algorithms, key sizes of at least 2048 bits should be considered for secure and highly protected applications
3 Passphrases and passwords must be used to encrypt the key if it is stored on the disk	9 In the case of hash algorithms, a hash length of 256 bits or higher should be considered for secure applications
4 Keys should not be present inside the source code or binaries	10 Recommended tools and products should be preferred over creating self-engineered crypto algorithms and functions
5 For certificate signing, transfer of private keys should not be allowed	11 Avoid encryption key relationships being simple, i.e., each encrypted key should be created from KDF
6 For symmetric algorithms, key sizes of 256 bits should be preferred for a secure system, especially in large transactions	12 The output of the hash function should have a higher bit length , making it difficult to decrypt

3 Information Security and Ethical Hacking Overview

Number of Questions – 8

Description:

- Information Security Overview
- Hacking Methodologies and Frameworks
- Hacking Concepts
- Ethical Hacking Concepts
- Information Security Controls
- Information Security Laws and Standards

Laws and Standards

- ISO 27001 - Security standard based on the British BS7799 standard, focuses on security governance
- NIST-800-53 - Catalogs security and privacy controls for federal information systems, created to help implementation of FISMA
- ISO 27002 AND 17799 - Based on BS799 but focuses on security objectives and provides security controls based on industry's best practice
- FISMA - "Federal Information Security Modernization Act of 2002" A law updated in 2004 to codify the authority of the Department of Homeland Security regarding implementation of information security policies
- FITARA - "Federal Information Technology Acquisition Reform Act" A 2013 bill that was intended to change the framework that determines how the US GOV purchases technology

- HIPAA - "Health Insurance Portability and Accountability Act" a law that sets privacy standards to protect patient medical records and health information shared between doctors, hospitals and insurance providers
- PCI-DSS - "Payment Card Industry Data Security Standard" Standard for organizations handling Credit Cards, ATM cards and other POS cards
- COBIT - "Control Object for Information and Related Technology" IT Governance framework and toolset, created by ISACA and ITGI
- SOX - "Sarbanes-Oxley Act" Law that requires publicly traded companies to submit independent audits and to properly disclose financial information
- GLBA - "U. S Gramm-Leach-Bliley Act" Law that protects the confidentiality and integrity of personal information that is collected by financial institutions.
- CSIRT - "Computer Security Incident Response Team" CSIRT provided a single point of contact when reporting computer security incidents
- ITIL - "Information Technology Infrastructure Library" - An operational framework developed in the '80s that standardizes IT management procedures
- OSSTM Compliance - "Open Source Security Testing Methodology Manual" maintained by ISECOM , defines three types of compliance
 - Legislative - Deals with government regulations (Such as SOX and HIPAA)
 - Contractual - Deals with industry/group requirement (Such as PCI DSS)
 - Standards based - Deals with practices that must be followed by members of a given group/organization (Such as ITIL ,ISO and OSSTMM itself)
- OSSTM Controls (OSSTM Class A - Interactive Controls)
 - Authentication - Provides for identification and authorization based on credentials
 - Indemnification - Provided contractual protection against loss or damage

- Subjugation - Ensures that interactions occur according to processes defined by the asset owner
- Continuity - Maintains interactivity with assets if corruption or failure occurs
- Resilience - Protects assets from corruption and failure
- OSSTM Class B - Process Controls
 - Non-repudiation - Prevents participants from denying their actions
 - Confidentiality - Ensures that only participants know of an asset
 - Privacy - Ensures that only participants have access to the asset
 - Integrity - Ensures that only participants know when assets and processes change
 - Alarm - Notifies participants when interactions occur

Controls

- Directive - Also known as procedural controls because they deal with company procedures such as security policies, operations plan, and guidelines.
- Deterrent - Controls that are used to dissuade potential attackers, such as signs that warn possible attackers about the alarm system and monitoring in place.
- Preventive - Controls used to stop potential attacks by preventing users from performing specific actions, such as encryption and authentication
- Compensating - Controls used to supplement directive controls, such as administrator reviewing logs files for violations of company policy
- Detective - Controls used to monitor and alert malicious or unauthorized activity, such as IDS's and CCTV feeds monitored in real time
- Corrective - Controls used to repair damage caused by malicious events. Such as AntiVirus software and IPS (IPS being both detective and corrective control)

- Recovery

Law Categories

- Criminal - laws that protect public safety and usually have jail time attached
- Civil - private rights and remedies
- Common - laws that are based on societal customs

Penetration Test

- Clearly defined, full scale test of security controls
- Phases
 - Preparation - contracts and team determined
 - Assessment - all hacking phases (reconnaissance, scanning, attacks, etc.)
 - Post-Assessment - reports & conclusions
- Types
 - Black Box - done without any knowledge of the system or network
 - White Box – complete knowledge of the system
 - Grey Box - has some knowledge of the system and/or network

Types of Reconnaissance

- Passive - gathering information about the target without their knowledge
- Active - uses tools and techniques that may or may not be discovered

Hacking Phases

1. Reconnaissance - gathering evidence about targets
2. Scanning & Enumeration - obtaining more in-depth information about targets
3. Gaining Access - attacks are leveled to gain access to a system
4. Maintaining Access - items put in place to ensure future access
5. Covering Tracks - steps taken to conceal success and intrusion

Phases of Ethical Hacking



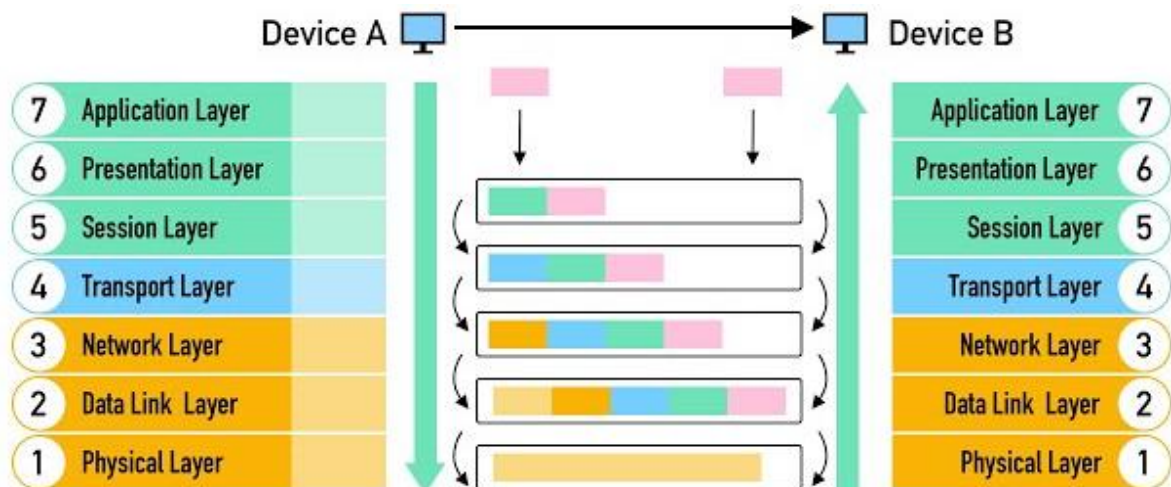
Attack Types

- Operating System (OS) - attacks targeting OS flaws or security issues inside such as guest accounts or default passwords
- Application Level - attacks on programming code and software logic

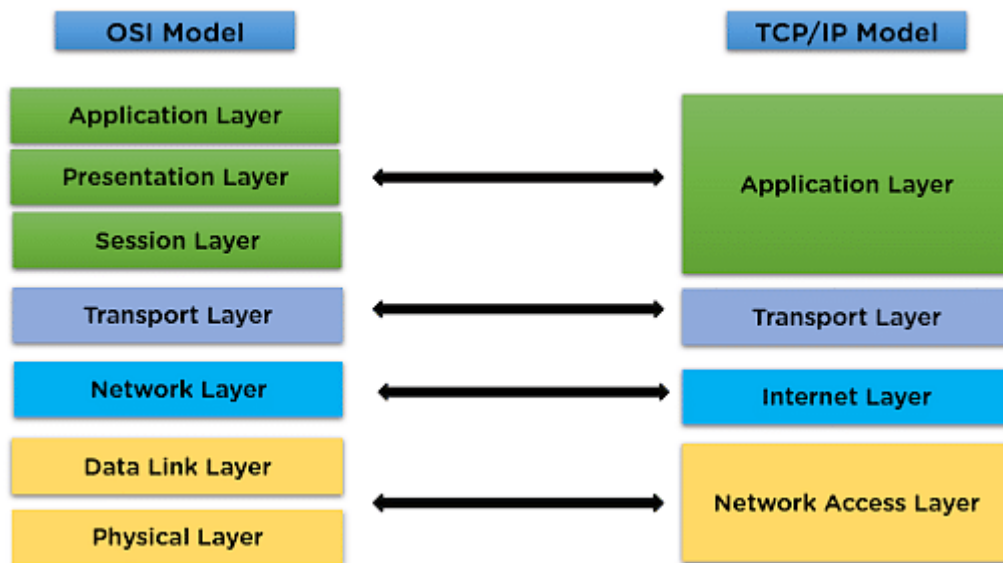
- Shrink-Wrap Code - attack takes advantage of built-in code or scripts
- Misconfiguration - attack takes advantage of systems that are misconfigured due to improper configuration or default configuration
- Infowar - the use of offensive and defensive techniques to create an advantage

OSI Model

Layer	Description	Technologies	Data Unit
1	Physical	USB, Bluetooth	Bit
2	Data Link	ARP, PPP	Frame
3	Network	IP	Packet
4	Transport	TCP	Segment
5	Session	X255, SCP	Data
6	Presentation	AFP, MIME	Data
7	Application	FTP, HTTP, SMTP	Data



TCP/IP Model



TCP Handshake

- SYN -> SYN-ACK -> ACK

Network Security Zones

- Internet - uncontrollable
- Internet DMZ - controlled buffer network
- Production Network Zone - very restricted; controls direct access from uncontrolled zones; has no users
- Intranet Zone - controlled; has little to no heavy restrictions
- Management Network Zone - might find VLANs and IPSEC; highly secure; strict policies

Vulnerabilities

- Common Vulnerability Scoring System (CVSS) - places numerical scores based on severity
- National Vulnerability Database (NVD) - US government repository of vulnerabilities

Vulnerability Categories

- Misconfiguration - improperly configuring a service or application
- Default installation - failure to change settings in an application that come by default
- Buffer overflow - code execution flaw
- Missing patches - systems that have not been patched
- Design flaws - flaws inherent to system design such as encryption and data validation
- Operating System Flaws - flaws specific to each OS
- Default passwords - leaving default passwords that come with system/application

Vulnerability Management Tools

- Nessus
- Qualys
- GFI Languard
- Nikto
- OpenVAS
- Retina CS

Terms to Know

- Hack value - perceived value or worth of a target as seen by the attacker

- Zero-day attack - an attack that occurs before a vendor knows or is able to patch a flaw
- Doxing - searching for and publishing information about an individual usually with a malicious intent
- Enterprise Information Security Architecture (EISA) - a process that determines how systems work within an organization
- Incident management - deals with specific incidents to mitigate the attack

Threat Modelling

- Identify security objectives - This step defines what needs to be protected and why. This includes understanding the value of the system, data and functions to be protected
- Application Overview - Gathering all the key information about the application. This stage helps to understand how the system works.
- Decompose application - Detailed analysis of the application architecture: what components it consists of, how they interact with each other.
- Identify threats - This stage analyzes what can go wrong and what actions attackers can take
- Identify vulnerabilities - Once threats have been identified, the specific vulnerabilities in the system that allow these threats to materialize are analyzed

Risk Management

Risk management - the process of reducing and maintaining risk at an acceptable level by means of a well-defined and actively employed security program

- Risk identification - The initial step of the risk management plan. Its main aim is to identify the risks, including the sources, causes, and consequences of the internal and external

risks affecting the security of the organization before they cause harm. The risk identification process depends on the skill set of people, and it differs from one organization to another.

- Risk assessment - Assesses the organization's risk and provides an estimate of the likelihood and impact of the risk. Risk assessment is an ongoing iterative process that assigns priorities for risk mitigation and implementation plans, which in turn help to determine the quantitative and qualitative value of risk.
 - Risk treatment - Selects and implements appropriate controls for the identified risks
 - Risk tracking - Ensures appropriate controls are implemented to handle known risks and calculates the chances of a new risk occurring. The purpose of this step is to identify treatments for the risks that fall outside the department's risk tolerance and provide an understanding of the level of risk with controls and treatments. It identifies the priority order in which individual risks should be treated, monitored, and reviewed.
 - Risk review - Evaluates the performance of the implemented risk management strategies
- ***Uses risk analysis matrix to determine threat level

Business Analysis

- Business Impact Analysis (BIA)
 - Maximum Tolerable Downtime (MTD)
- Business Continuity Plan (BCP)
 - Disaster Recovery Plan (DRP)
- Annualized Loss Expectancy (ALE)
 - Annual Rate of Occurrence (ARO)
 - Single Loss Expectancy (SLE) $ALE = SLE * ARO$

CIA Triad

- Confidentiality - passwords, encryption
- Integrity - hashing, digital signatures
- Availability - anti-dos solutions



***Bit flipping is an example of an integrity attack. The outcome is not to gain information - it is to obscure the data from the actual user.

***Confidentiality != authentication - MAC address spoofing is an authentication attack

The Hats/Type Hackers

- White Hat - ethical hackers
- Black Hat - hackers that seek to perform malicious activities
- Gray Hat - hackers that perform good or bad activities but do not have the permission of the organization they are hacking against

- Hactivist - someone who hacks for a cause
- Suicide Hackers - do not cause any impunity to themselves; hack to get the job done
- Cyberterrorist - motivated by religious or political beliefs to create fear or disruption
- State-Sponsored Hacker - hacker that is hired by a government
- Ethical hacker - employs tools that hackers use with a customer's permission; always obtains an agreement from the client with specific objectives before any testing is done
- Cracker - uses tools for personal gain or destructive purposes
- Script Kiddie - uneducated in security methods, but uses tools that are freely available to perform malicious activities
- Phreaker - manipulates telephone systems

Types of Access Control

- Discretionary Access Control (DAC) - Access control is determined by the owner of the resource. He decides who can read, modify or execute the file.
- Mandatory Access Control (MAC) - Access is governed by a centralized policy, not by the resource owner. All subjects (users, processes) and objects (files, databases) have security labels, and access is only possible if they match these labels.
- Role-Based Access Control (RBAC) - Access is granted based on roles rather than individual users. A role is a set of permissions, and users are assigned roles according to their function in the organization.
- Attribute-Based Access Control (ABAC) - Access decisions are made based on attributes of the user, resource, action, and environment.

Security Policies

- Access Control - what resources are protected and who can access them

- Information Security - what systems can be used for
- Information Protection - defines data sensitivity levels
- Password - all things about passwords (how long, characters required, etc.)
- E-Mail - proper and allowable use of email systems
- Information Audit - defines the framework used for auditing

Policy Categorizations

- Promiscuous - wide open
- Permissive - blocks only known dangerous things
- Prudent - blocks most and only allows things for business purposes
- Paranoid - locks everything down

4 Mobile Platform, IoT, and OT Hacking

Number of Questions – 10

Sub Domain/Description:

- Hacking Mobile Platforms
 - Mobile Platform Attack Vectors
 - Hacking Android OS
 - Hacking iOS
 - Mobile Device Management
 - Mobile Security Guidelines and Tools
- IoT and OT Hacking
 - IoT Concepts
 - IoT Attacks
 - IoT Hacking Methodology
 - IoT Attack Countermeasures
 - OT Concepts
 - OT Attacks
 - OT Hacking Methodology
 - OT Attack Countermeasures

Mobile Platform Hacking

Three Main Avenues of Attack

- Device Attacks - browser based, SMS, application attacks, rooted/jailbroken devices
- Network Attacks - DNS cache poisoning, rogue APs, packet sniffing

- Data Center (Cloud) Attacks - databases, photos, etc.

OWASP Top 10 Mobile Risks

- M1 - Improper Platform Usage - misuse of features or security controls (Android intents, TouchID, Keychain)
- M2 - Insecure Data Storage – improperly stored data and data leakage
- M3 - Insecure Communication - poor handshaking, incorrect SSL, clear-text communication
- M4 - Insecure Authentication - authenticating end user or bad session management
- M5 - Insufficient Cryptography - code that applies cryptography to an asset, but is insufficient (does NOT include SSL/TLS)
- M6 - Insecure Authorization - failures in authorization (access rights)
- M7 – Client Code Quality - catchall for code-level implementation problems
- M8 – Code Tampering - binary patching, resource modification, dynamic memory modification
- M9 - Reverse Engineering - reversing core binaries to find problems and exploits
- M10 - Extraneous Functionality - catchall for backdoors that were inadvertently placed by coders

Mobile Platforms

- Android - platform built by Google
 - Rooting - name given to the ability to have root access on an Android device
 - Tools:
 - ❖ KingoRoot

- ❖ TunesGo
- ❖ OneClickRoot
- ❖ ■ MTK Droid
- iOS - platform built by Apple
 - Jailbreaking - different levels of rooting an iOS device
 - Tools:
 - ❖ evasi0n7
 - ❖ GeekSn0w
 - ❖ Pangu
 - ❖ Redsn0w
 - ❖ Absinthe
 - ❖ Cydia
 - Techniques
 - Untethered - kernel remains patched after reboot, with or without a system connection
 - Semi-Tethered - reboot no longer retains patch; must use installed jailbreak software to re-jailbreak
 - Tethered - reboot removes all jailbreaking patches; phone may get in boot loop requiring USB to repair
 - Types
 - Userland exploit - found in the system itself; gains root access; does not provide admin; can be patched by Apple
 - iBoot exploit - found in bootloader called iBoot; uses vulnerability to turn codesign off; semi-tethered; can be patched
 - BootROM exploit - allows access to file system, iBoot and custom boot logos; found in device's first bootloader; cannot be patched
- App Store attacks - since some App stores are not vetted, malicious apps can be placed there

- Phishing attacks - mobile phones have more data to be stolen and are just as vulnerable as desktops
- Android Device Administration API - allows for security-aware apps that may help
- Bring Your Own Device (BYOD) - dangerous for organizations because not all phones can be locked down by default
- Mobile Device Management - like group policy on Windows; helps enforce security and deploy apps from enterprise
 - MDM solutions include XenMobile, IBM, MaaS360, AirWatch and MobiControl
- Bluetooth attacks - if a mobile device can be connected to easily, it can fall prey to Bluetooth attacks
 - Discovery mode - how the device reacts to inquiries from other devices
 - Discoverable - answers all inquiries
 - Limited Discoverable - restricts the action
 - Nondiscoverable - ignores all inquiries
 - Pairing mode – how the device deals with pairing requests
 - Pairable - accepts all requests
 - Nonpairable - rejects all connection requests

Mobile Attacks

- SMS Phishing - sending texts with malicious links
 - People tend to trust these more because they happen less
 - Trojans Available to Send
 - Obad
 - Fakedefender

- TRAMPS
 - ZitMo o Spyware
 - Mobile Spy
 - Spyera
- Mobile platform features such as Find my iPhone, Android device tracking and the like can be hacked to find devices, etc.
- Mobile Attack Platforms - tools that allow you to attack from your phone
 - Network Spoofer
 - DroidSheep
 - Nmap

Bluetooth Attacks

- Bluesmacking - denial of service against device
- Bluejacking - sending unsolicited messages
- Bluesniffing - attempt to discover Bluetooth devices
- Bluebugging - remotely using a device's features
- Bluesnarfing - theft of data from a device
- Blueprinting - collecting device information over Bluetooth

Bluetooth Attack Tools

- BlueScanner - finds devices around you o
- BT Browser - another tool for finding and enumerating devices
- Bluesniff and btCrawler - sniffing programs with GUI

- Bloover - can perform
- Bluebugging
- PhoneSnoop - good spyware option for Blackberry
- Super Bluetooth Hack - all-in-one package that allows you to do almost anything

IoT Architecture

- Definition - a collection of devices using sensors, software, storage and electronics to collect, analyze, store and share data
- Three Basic Components
 - Sensing Technology
 - IoT gateways
 - The cloud
- Operating Systems
 - RIOT OS - embedded systems, actuator boards, sensors; is energy efficient
 - ARM mbed OS - mostly used on wearables and other low-powered devices
 - RealSense OS X - Intel's depth sensing version; mostly found in cameras and other sensors
 - Nucleus RTOS - used in aerospace, medical and industrial applications
 - Brillo – Android-based OS; generally found in thermostats
 - Contiki - OS made for low-power devices; found mostly in street lighting and sound monitoring
 - Zephyr - option for low-power devices and devices without many resources
 - Ubuntu Core - used in robots and drones; known as "snappy"

- Integrity RTOS - found in aerospace, medical, defense, industrial and automotive sensors
- Apache Mynewt - used in devices using Bluetooth Low Energy Protocol

Methods of Communicating

- Device to Device - communicates directly with other IoT devices
- Device to Cloud - communicates directly to a cloud service
- Device to Gateway - communicates with a gateway before sending to the cloud
- Back-End Data Sharing - like device to cloud but adds abilities for parties to collect and use the data

Architecture Levels

- Edge Technology Layer - consists of sensors, RFID tags, readers and the devices
- Access Gateway Layer - first data handling, message identification and routing
- Internet Layer - crucial layer which serves as main component to allow communication
- Middleware Layer - sits between application and hardware; handles data and device management, data analysis and aggregation
- Application Layer - responsible for delivery of services and data to the user

IoT Vulnerabilities and Attacks

- I1 - Insecure Web Interface - problems such as account enumeration, weak credentials, and no account lockout
- I2 - Insufficient Authentication/Authorization - assumes interfaces will only be exposed on internal networks and thus is a flaw

- I3 - Insecure Network Services - may be susceptible to buffer overflow or DoS attacks
- I4 - Lack of Transport Encryption/Integrity Verification - data transported without encryption
- I5 - Privacy Concerns - due to collection of personal data
- I6 - Insecure Cloud Interface - easy-to-guess credentials make enumeration easy
- I7 - Insecure Mobile Interface - easy-to-guess credentials on mobile interface
- I8 - Insufficient Security Configurability - cannot change security which causes default passwords and configuration
- I9 - Insecure Software/Firmware - lack of a device to be updated or devices that do not check for updates
- I10 - Poor Physical Security - because of the nature of devices, these can easily be stolen

Attack

- Sybil Attack - uses multiple forged identities to create the illusion of traffic
- HVAC Attacks - attacks on HVAC systems
- Rolling Code - the ability to jam a key fob's communications, steal the code and then create a subsequent code
- BlueBorne Attack - attacks against Bluetooth devices
- Other attacks already enumerated in other sections still apply such as MITM, ransomware, side channel

IoT Hacking Methodology

Steps

- Information Gathering - gathering information about the devices; useful resource is

- Shodan (Google for IoT devices connected to Internet)
 - Foren6 - IoT traffic sniffer
- Vulnerability Scanning - same as normal methodology - looks for vulnerabilities
 - Tools:
 - ❖ Nmap
 - ❖ RIoT Vulnerability Scanner
 - ❖ beSTORM
 - ❖ IoTsploit
 - ❖ IoT Inspector
- Launching Attacks
 - Tools
 - ❖ Firmalyzer
 - ❖ KillerBee
 - ❖ JTAGulator
 - ❖ Attify
- Gaining Access - same objectives as normal methodology
 - Maintaining Access - same objectives as normal methodology

5 Network and Perimeter Hacking

Number of Questions - 18

Sub Domain/Description

- Sniffing
 - Sniffing Concepts
 - Sniffing Technique: MAC Attacks
 - Sniffing Technique: DHCP Attacks
 - Sniffing Technique: ARP Poisoning
 - Sniffing Technique: Spoofing Attacks
 - Sniffing Technique: DNS Poisoning
 - Sniffing Tools
 - Sniffing Countermeasures
 - Sniffing Detection Techniques
- Social Engineering
 - Social Engineering Concepts
 - Social Engineering Techniques
 - Insider Threats
 - Impersonation on Social Networking Sites
 - Identity Theft
 - Social Engineering Countermeasures
- Denial-of-Service
 - DoS/DDoS Concepts
 - Botnets
 - DoS/DDoS Attack Techniques
 - DDoS Case Study
 - DoS/DDoS Attack Countermeasures
 - DoS/DDoS Protection Tools

- Session Hijacking
 - Session Hijacking Concepts
 - Application-Level Session Hijacking
 - Network-Level Session Hijacking
 - Session Hijacking Tools
 - Session Hijacking Countermeasures
- Evading IDS, Firewalls, and Honeypots
 - IDS, IPS, Firewall, and Honeypot Concepts
 - IDS, IPS, Firewall, and Honeypot Solutions
 - Evading IDS
 - Evading Firewalls
 - Evading NAC and Endpoint Security
 - IDS/Firewall Evading Tools
 - Detecting Honeypots
 - IDS/Firewall Evasion Countermeasures

IDS Firewalls and Honeypot concepts

Intrusion detection system

- inspects inbound and outbound traffic for suspicious activity
- Checks traffic for signatures and patterns and alarms when a match is found
- IDS can be place outside of inside a firewall
- Before deploying an IDS it is important to understand how information flows through the network
- Signature Recognition – Tries to identify events that are the miss uses of network resources

- Anomaly Detection – detects intrusions based on fixed behaviors of the users or components in a system
- Protocol Anomaly Detection – Explores anomalies in the way vendors deploy the tcp/ip specification

General Indication of Intrusions

- File System Intrusions
 - New unfamiliar files or programs
 - Change of file permissions
 - Unexplained change in file size
 - Rouge files on the system that do not correspond to the master list of signed files
 - Missing files
- Network Intrusions
 - Repeated probes of available services on machines
 - Connections from unusual locations
 - Repeated login attempts to remote host
 - Sudden influx of log data
- System Intrusions
 - Short of incomplete logs
 - Unusually slow system
 - Missing logs or logs with incorrect permissions
 - Modifications to system software and config files
 - Unusual guis or text messages

- Gaps in system accounting
- System crashes or reboots
- Unfamiliar processes

Types of IDS

- Network based intrusion detection systems
 - Runs in promiscuous mode and listens for patterns indicative of an intrusion
 - Detects activity like DoS, port scans, or attempts to crack into computers by watching network traffic
- Host based intrusion detection systems
 - Audits for events that occur on specific host
 - Not as common due to overhead of monitoring each system event
- LFM IDS
 - Monitors log files and watches for strange activity
- File integrity checking
 - Watches file and makes sure they are not modified

IDS Alerts

- True positive – legitimate attack
- False positive – no attack
- False negative – legitimate attack that was not alerted on
- True negative - IDS does not raise an alarm when an attack has not taken place

DeMilitarized Zone (DMZ)

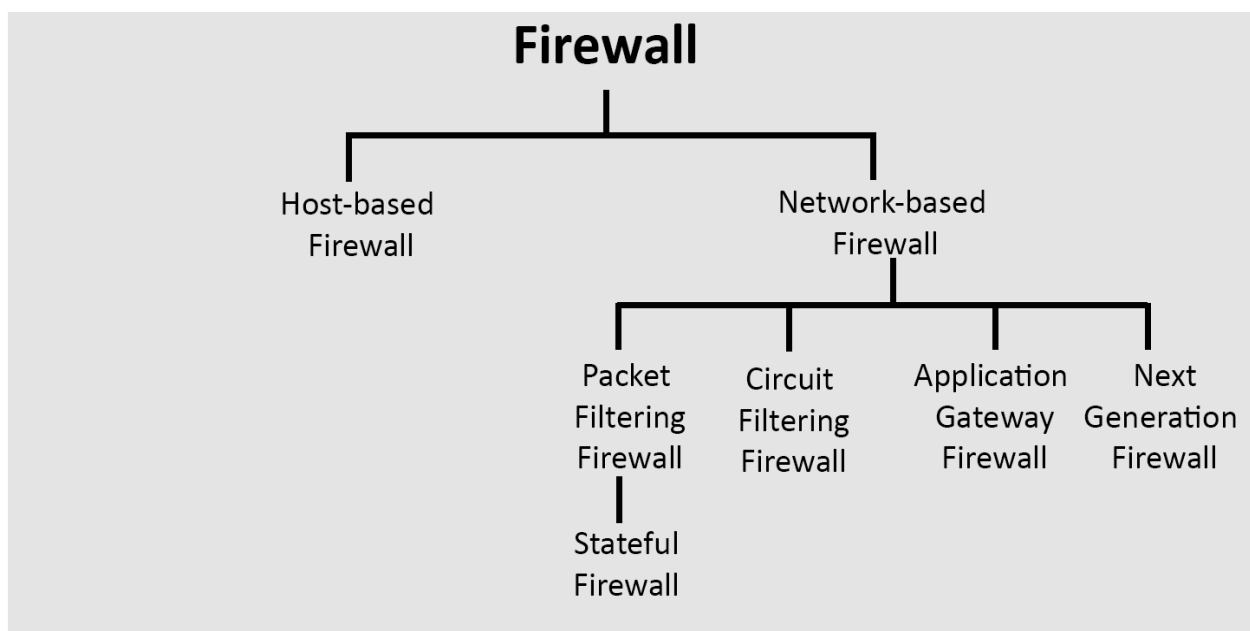
- DMZ is a network that serves as a buffer between the internal secure network and insecure internet
- Created using a firewall with three or more network interfaces
 - Is an untrusted network where servers that are accessed by the public and be connected to by hosts on the internet

Types of firewalls

- Hardware firewall
 - A dedicated stand alone device
 - Filters network traffic using packet filtering
 - Used to filter out the network traffic of large business networks
 - Has increased level of security controls
 - Faster speed
 - Minimal interference
 - More expensive
 - Hard to implement and configure and requires more space
- Software Firewall
 - A firewall software program installed on a computer just like normal software
 - Used to filter traffic for individual home users
 - Only filters traffic for the computer on which it is installed
 - Less expensive than hardware firewalls
 - Ideal for personal or home use

- Easier to configure and reconfigure
- Consumer host resources
- Difficult to uninstall
- Not appropriate for environments requiring faster response times
- Packet Filtering Firewall
 - Packet filtering firewalls work at the network layer and are usually part of a router
 - Each packet is compared to a set of criteria before being forwarded
 - Depending on the packet and the criteria the firewall will drop or forward the packet
 - Rules can include source and destination ip address, the source and the destination port number, the protocol used, TCP flag bits, direction, or interface
- Circuit-Level Gateway firewall
 - Session layer firewall/TCP layer
 - Information passed to a remote computer through a circuit level gateway appears to have originated from the gateway
 - They monitor requests to create sessions and then determine if those sessions are allowed
 - Circuit proxy firewalls allow or prevent data streams
 - THEY DO NOT FILTER INDIVIDUAL PACKETS!!
- Application level firewall
 - Application level gateways (proxies) can filter packets at the application layer
 - Incoming and outgoing traffic is restricted to services supported by proxy all other service requests are denied

- Application-level gateways configured as a web proxy prohibit FTP, gopher, telnet, or other traffic
- Examine traffic and filter on application specific commands such as http post
- Active application level firewalls - examine all incoming request and will only allow genuine request through
- Passive application level firewalls – Work like IDS they check all incoming request but do not allow or deny just log the information
- Stateful multilayer inspection firewall
 - Combine the aspects of three types of firewalls
 - ❖ Packet filtering
 - ❖ Circuit level
 - ❖ Application level
 - They filter packets at the network layer to determine if a session packet is legitimate and they evaluate the contents of the packet at the application layer



Application Proxy

- Filters connections for specific services
- Act as proxy servers
- Filter connections based on services and protocols
- Example an ftp proxy will only allow ftp traffic to pass through
- Advantages
 - Can be good at logging because they understand the application layer
 - Proxy services reduce the load on the network links as they are capable of caching information
 - Perform user level authentication
 - Automatically protect weak or faulty ip implementations
- Disadvantages
 - Proxy services lag behind non proxy services until suitable proxy software is available
 - Each service in a proxy may use different servers
 - Proxy services may require changes in the client, application, and procedures

Network Address Translation (NAT)

- Separates IP address into two sets
- Allows LAN devices to use WAN IP addresses
- NAT modifies the packets the router sends

- Has the ability to change the address of a packet and make it appear to have arrived from a valid address
- It limits the number of public IP address and organization can use
- It can act as a firewall filtering technique where it allows only those connections which originate on the inside network and will block connections which originate on the outside network
- Advantages
 - NAT helps enforce firewall control over outbound connections
 - Restricts incoming traffic and allows only packets that are part of a current interaction initiated from the inside
- Disadvantage
 - NAT has to guess how long to keep a translation
 - NAT interferes with encryption and authentication services
 - Dynamic allocation of ports may interfere with packet filtering

TCP/IP & OSI in Relation to Firewalls

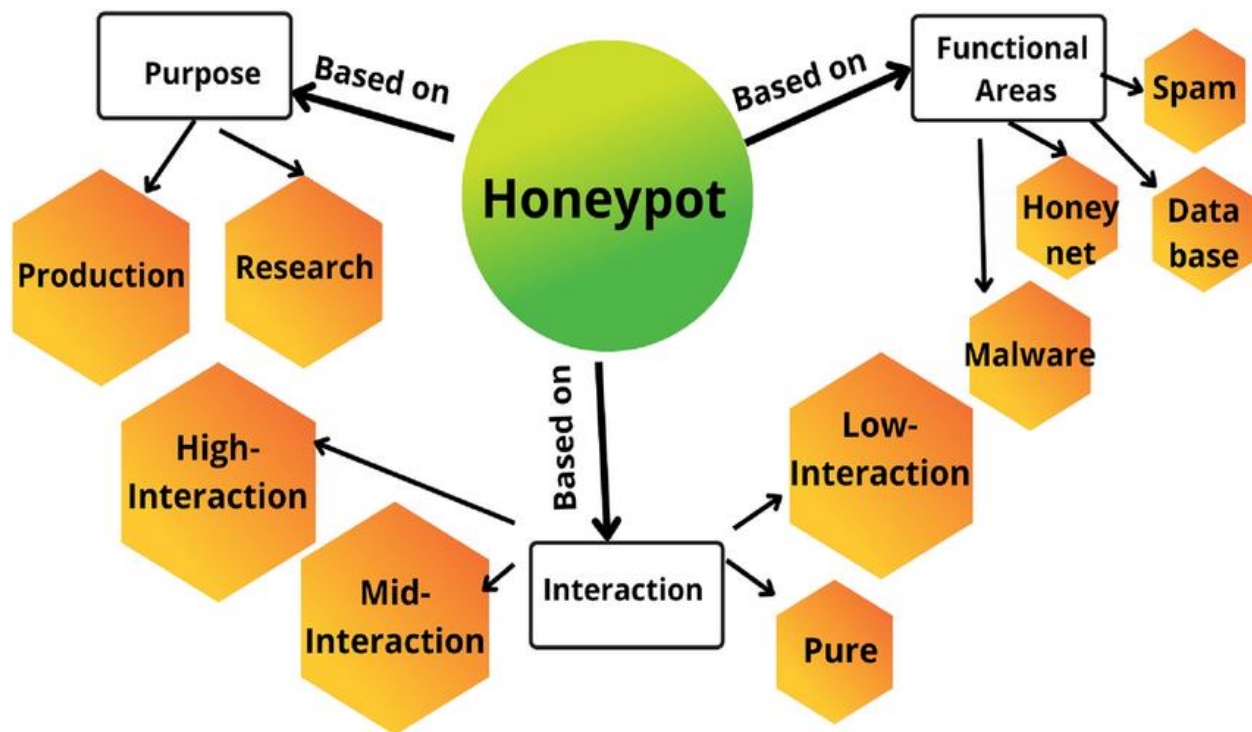
4-Layer TCP/IP	5-Layer TCP/IP	OSI Model	
4. Application Layer	5. Application Layer	7. Application Layer	Application gateways
		6. Presentation Layer	
		5. Session Layer	
3. Transport Layer	4. Transport Layer	4. Transport Layer	Circuit gateways
2. Internet Layer	3. Network Layer	3. Network Layer	Packet filtering
1. Link	2. Data Link Layer	2. Data Link Layer	MAC layer
	1. Physical Layer	1. Physical Layer	

Virtual Private Network (VPN)

- Private network constructed using public networks
- Used to secure transmission of sensitive information over an untrusted network using encapsulation and encryption
- Establishes a virtual point to point connection through use of dedicated connections
- Only devices running the VPN software can access the VPN
- Firewall Limitations

Honeypot

- Setup to attract and trap people who attempt to penetrate an organization's network
- Does not have any production value
- Any traffic to it is likely to probe attack or compromise
- Can log port access attempts
- Monitor attackers' keystrokes
- Can be used for early warning signs



Types of fHoneypots

- Low Interaction Honeypots
 - Simulate only a limited number of services and applications of a target system or network
 - Set to collect higher level information about attack vectors such as network probes and worm activities
- Medium Interaction Honeypots
 - Simulate a real operating system applications and its services
 - Can respond to pre configured commands therefor risk of intrusion is increased
- High interaction Honeypots
 - Simulates all services
 - Captures complete information about an attack vector such as attack techniques tools and intent of the attack
- Production Honeypots
 - Emulate real production networks

- Set to collect internal flaws and attackers within an organization \
- Research Honeypots
 - These are high interaction honeypots primarily deployed in research institutes government or military organizations
 - Capture in depth information about the way an attack is performed vulnerabilities exploited and the attack techniques used by the attacker

IDS Firewall and Honeypot Solutions

Snort

- Open source network IDS performs real time traffic analysis and packet logging on IP networks
- Performs protocol analysis and content searching / matching
- Used to detect a variety of attacks and probes
- Uses flexible rules language to describe traffic it should collect or pass as well as a detection engine that utilizes a modular plugin architecture

Uses of snort

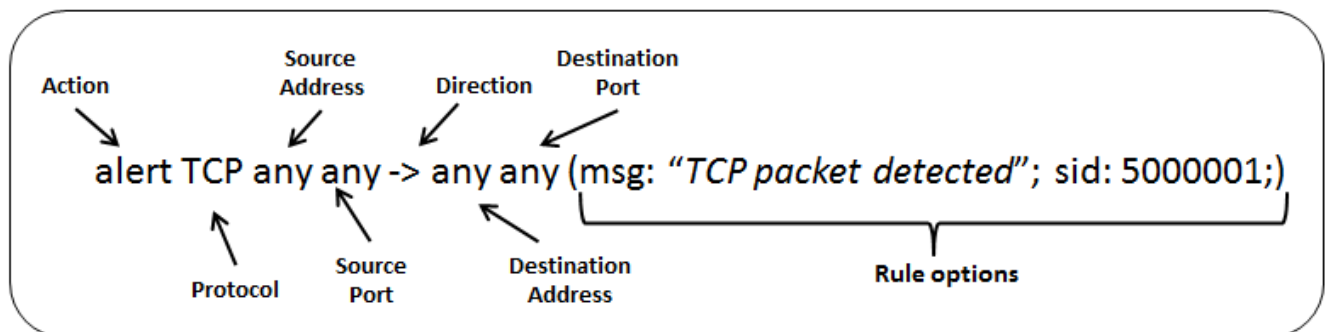
○ Straight packer sniffer like TCP dump ○ Packet logger ○ Network IPS

Snort Rules

- Enables custom rules to meet the needs of networks
 - Help differentiate between normal internet activities and malicious activities
 - Must be contained in a single line snort does not handle rules on multiple lines
- Snort rules have two parts
 - Rule header and rule options

Snort Rules Actions and IP Protocols

- Rule header stores the complete set of rules to identify the packet and determine the action that is being performed
- The rule action alerts snort when it finds a packet the matches the rule o
- Three actions snort can take:
 - Alert – Generates an alert using the selected alert method and then logs the packet
 - Log– Logs the packet
 - Pass – drops / ignores the packet
- Three IP protocols available for snort:
 - TCP
 - UDP
 - ICMP



IDS Tipping Point

- In line threat protection software
- Does not affect performance and productivity

AlienVault

- OpenSource SIEM
- Normalization and correlation

- Advance threat detection

KFSensor

- Host Based IDS that acts as a Honeypot to attract the detection hacker and worms simulates vulnerable system services and trojan

Specter

- Honeypot based on IDS
- Offers common internet services

Evading IDS

1 Insertion Attack	7 Unicode Evasion	13 Polymorphic Shellcode
2 Evasion	8 Fragmentation Attack	14 ASCII Shellcode
3 Denial-of-Service Attack	9 Overlapping Fragments	15 Application-Layer Attacks
4 Obfuscating	10 Time-To-Live Attacks	16 Desynchronization
5 False Positive Generation	11 Invalid RST Packets	17 Encryption
6 Session Splicing	12 Urgency Flag	18 Flooding

Insertion Attack

- Attacker confuses the IDS by forcing it to read invalid packets
- An IDS blindly believes and accepts a packet that an end system rejects and the attacker exploits this condition and inserts data into the IDS
- Occurs when NIDS is less strict in processing packets than the internal network

- The attacker obscures extra traffic and IDS concludes the traffic is harmless
- The IDS gets more packets than the destination
- IDS and the end system construct two different strings

Evasion

- End System Accepts a packet that an IDS rejects
- Using this technique an attacker exploits the host computer without the IDS ever realizing it
- Attacker sends portions of the request in packet that the IDS mistakenly rejects allowing the removal of parts of the stream from the IDS
- The IDS gets fewer packets than the destination

DoS

- IDSs use a centralized server for logging alerts
- If attackers know the IP address of the centralized server they can perform a DoS or other hack to slow down or crash the server
- As result attacker intrusion attempts will not be logged

Obfuscation

- Encode the attack packet payload
- Attackers manipulate the path referenced in the signature to fool the HIDS
- Attackers can encode attack patterns in Unicode to bypass IDS filtering but be understood by an iis webserver
- Polymorphic code is another means to circumvent signature based IDS by creating unique attack patterns

- Use encrypted protocols such as https so the IDS cant read the packet False Positive Generation
- Craft malicious packets just to generate alerts
- These packets generate a large number of false positive alerts
- False positives are used to hide the real attack traffic
- Makes it difficult to differentiate the attack traffic with the false positives

Session Splicing

- Attacker splits the attack traffic into many packets
 - It is effective against IDS that do not reconstruct packets before checking them against intrusion signatures
 - If attackers are aware of delay in packet reassembly at the IDS the can add delay between packet transmissions to bypass the reassembly
 - IDS stops reassembly if they do not receive packets within a certain time
 - IDS will stop working if the target host keeps session active for a time longer than the IDS reassembly time
 - Any attack attempt after a successful splicing attack will not be logged by the IDS
- ### **Unicode Evasion**
- Unicode is a character coding system to support worldwide interchange processing and display of the written texts
 - In the Unicode space all the code points are treated differently but it is possible that there could be multiple representations of a single character
 - Because of this complexity some IDS handle Unicode improperly
 - Attacker convert attack string into Unicode to avoid IDS

Fragmentation Attack

- Can be used when fragmentation timeouts vary between IDS and host
- If a fragment reassembly timeout is 10 sec at the IDS and 20 sec at the target system attackers will send the second fragment after 15 secs
- IDS will drop the fragment as the second fragment is received but the target will reassemble the fragment
- When an IDS timeout exceeds the Victims timeout multiple fragments can be sent at different times so that the IDS receives some packets and the target receives other

Overlapping Fragments

- Generates a series of tiny fragments with overlapping TCP sequence numbers

Time to live

- Attacker needs to have prior knowledge of the topology
- This information can be obtained using tools such as traceroute
- IDS will receive both fragments target receives first fragment only
- Invalid RST packet
- Attacker send RST packet to the IDS with an Invalid checksum
- IDS stops processing the packet thinking the TCP communication session has ended
- The target checks the RST packet checksum and drops it because it is invalid

Urgency Flag

- IDS do not consider the urgent pointer
 - This results in the IDS and the target systems having different sets of packets
- Polymorphic Shellcode

- Signature based NIDS identifies an attack by matching attack signatures with incoming and outgoing data
- Signatures are based off of commonly used string in shell code
- Polymorphic shellcode includes multiple signatures making it difficult to detect the signature
- Encode the payload using some technique and then place a decoder before the payload
- Shellcode is completely rewritten each time it is sent evading detection
- This technique also evades the commonly used shellcode strings

ASCII Shellcode

- ASCII Shellcode can be used to evade IDS because the pattern matching does not work with the ASCII values
- Scope of ASCII shellcode is limited as all assembly instructions cannot be converted to ASCII values directly
- Can be overcome by using other sets of instructions for converting ASCII values properly

Application Layer Attacks

- Uses compression to hide malicious code
- Signature IDS cannot detect signature in compressed files
- Enables an attacker to exploit the vulnerabilities in compressed data

Desynchronization

- Pre Connection SYN
 - Initial SYN packet is sent before the real connection

- If the SYN packet is received after the TCP control block is opened the IDS resets the appropriate sequence number to match that of the newly received SYN packet
- Attackers send fake SYN packets with a completely invalid sequence number to desync the IDS
- Stops the IDS from monitoring all legit traffic
- Post Connection SYN
 - Attempts to desync the IDS from the actual sequence numbers that the kernel is honoring
 - Send a post connection SYN packet in the data stream which have divergent sequence numbers
 - Target ignores the SYN packet as it references an already established connection
 - The point of the attack is to get the IDS to resync its notion of the sequence numbers to the new SYN packet
 - Causes the IDS to ignore legitimate part of the original stream
 - Once the IDS resyncs a RST packet is sent to close down the connection encryption

Encryption

- Encrypted sessions with the victim cant be read by the IDS

Flooding

- Attacker sends loads of unnecessary traffic to produce noise

Evading Firewalls

1 Firewalking	6 Using an IP Address in Place of a URL	11 Through External Systems
2 Banner Grabbing	7 Using a Proxy Server	12 Through MITM Attack
3 IP Address Spoofing	8 ICMP Tunneling	13 Through Content and XSS Attack
4 Source Routing	9 ACK Tunneling and HTTP Tunneling	14 Through HTML Smuggling
5 Tiny Fragments	10 SSH and DNS Tunneling	15 Through Windows BITS

Firewall Identification

- Port Scanning o Identifies open ports and services running
- Open ports can be further probed to identify the version of services
- Some firewall will uniquely identify themselves with how they respond to simple port scans

Firewalking

- Uses TTL values to determine gateway ACL filters and map networks by analyzing ip packet responses
- Attacker sends TCP or UDP packet to the targeted firewall with a TTL set to on hop greater than the firewall If the packet makes it through the firewall a TTL exceeded in transit will be returned

Banner Grabbing

- Banners announce the service that is running on the port
- Banner grabbing is a fingerprint method

- Main services that send out banners are FTP telnet and web servers

IP Address Spoofing

- IP Address spoofing is a hijack technique in which an attacker masquerades as a trusted host to conceal his identity spoof web sites hijack browsers or gain unauthorized access to a network
- Attackers modify the addressing information in the IP packet header and the source address bits field in order to bypass the firewall

Source Routing

- Allows the sender of a packer to specify the route the packet takes through the network
- As the packet travels through the nodes in the network each router examines the destination IP address and chooses the next hop to direct the packet to the destination
- In source routing the sender makes some of these decisions
- Allows the attacker to avoid going through the firewall

Tiny Fragments

- Attacker creates tiny packet fragments forcing some of the TCP packet header information into the next fragment
- IDS filter rules that specify patterns will not match with the fragmented packets due to broken header information
- The attack will succeed if the filtering router examines only the first fragment and allows other fragments to pass through
- This attack is used to avoid user defined filtering rules and works when the firewall checks only for the tcp header information

Bypass Blocked Sites using IP address in Place of URL

- This method involves typing the IP address directly in browsers address bar in place of typing the blocked website domain name

Bypass blocked sites using anonymous website surfing

- Uses VPN or proxy to encrypt traffic

Bypassing firewall through ICMP tunneling method

- Allows tunneling a backdoor shell in the data portion of ICMP echo packets
- The payload portion of an ICMP packet is not examined by many firewalls

Bypassing firewall through ACK tunneling Method

- Tunneling a backdoor application with TCP packets with ACK bit set
- ACK bit is used to acknowledge receipt of a packet

Bypassing Firewall through HTTP tunneling Method

- HTTP tunneling allow attackers to tunnel data through HTTP packets
- HTTP tunneling allow sending traffic for other services like FTP over HTTP or HTTPS

Bypassing firewall through SSH tunneling

- Attackers use openssh to encrypt and tunnel all the traffic from a local machine to a remote machine to avoid detection by perimeter security controls

Bypassing firewall through external systems

- Attackers make use of the DNS server and routing techniques to bypass restrictions

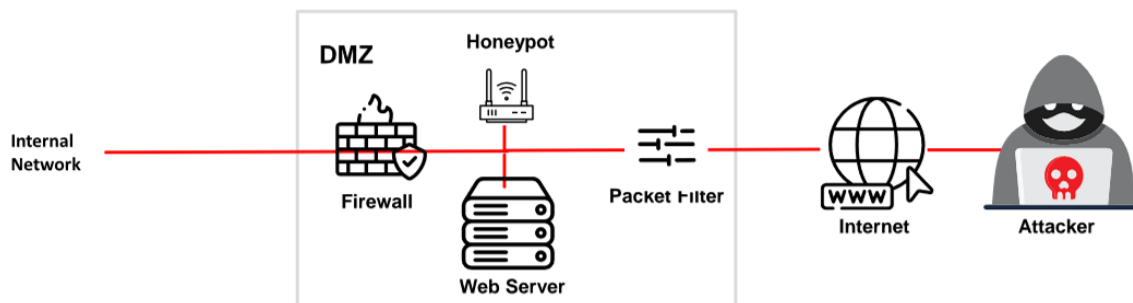
Bypassing through content

- Attacker sends the content containing malicious code to the user and tricks him/her to open it so that the malicious code can be executed

1 A honeypot is an information system resource that is expressly **set up to attract and trap people** who attempt to penetrate an **organization's network**

2 It has no authorized activity, does not have any **production value**, and any traffic to it is likely to be a **probe, attack, or compromise**

3 A honeypot can **log port access** attempts or monitor an **attacker's keystrokes**. These could be **early warnings** of a more concerted attack



Detecting Honeypots

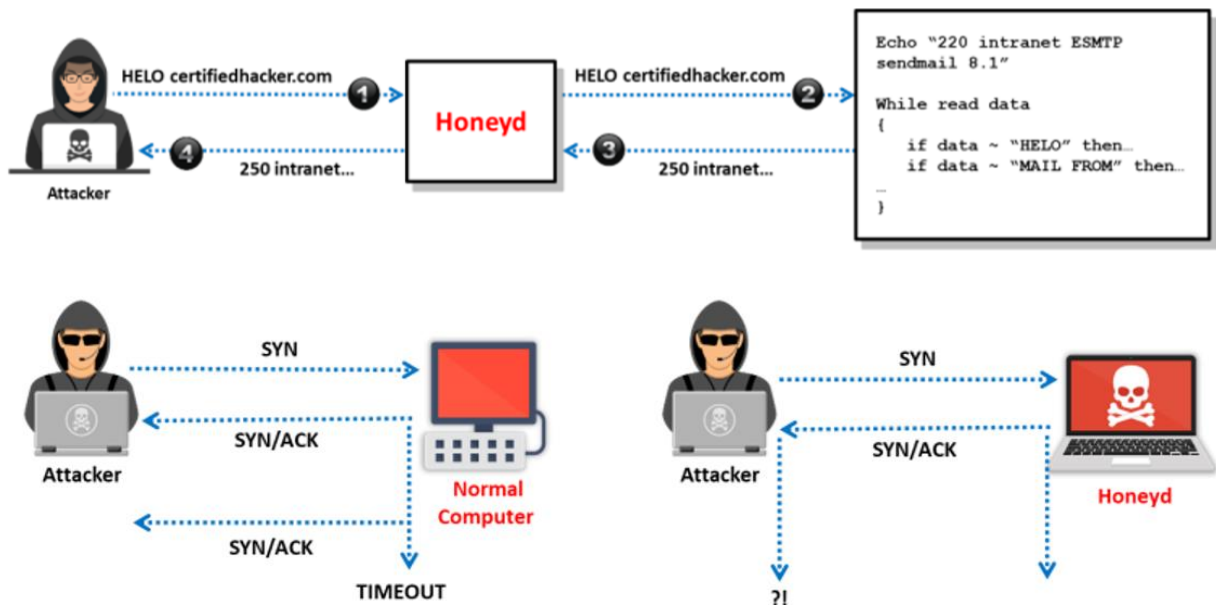
- Attacker can determine the presence of honeypots by probing the services running on a system
- Attackers craft malicious probe packets to scan for services such as HTTPS SMTPS and IMAPS
- Ports that show a particular service running but deny a three way handshake connection indicated the presence of a honeypot

Fingerprinting the Running Service	• Method: Identify specific services on network using nmap tool • Example Command: <code>nmap -sV -p 80 <target_ip></code> • Indicators: Discrepancies between claimed and actual service behaviors
Analyzing Response Time	• Method: Measure latency of responses using tools such as Ping, Traceroute or nmap • Example Command: <code>nmap -p 80 --scan-delay 1s --max-retries 5 <target_ip></code> • Indicators: Consistently higher response times and variability
Analyzing MAC Address	• Method: Examine MAC addresses to identify irregularities using tools such as Nmap or arp-scan • Example Command: <code>arp-scan --interface=eth0 --localnet</code> • Indicators: MAC addresses with unusual Organizationally Unique Identifiers (OUI)
Enumerating Unexpected Open Ports	• Method: Identify unusual or unexpected open ports using tools such as Nmap • Example Command: <code>nmap -p- <target_ip></code> • Indicators: Open ports that do not align with expected services
Analyzing System Configuration and Metadata	• Method: Scrutinize configuration settings, system banners, and metadata for inconsistencies • Indicators: Default configurations, outdated banners, and discrepancies in system information

Detecting and Defeating Honeypots

- Detecting presence of Layer 7 Tar Pits
 - Look at the latency of the response from the service
- Detecting presence of layer 4 tar pits
 - Analyze the TCP window size where tar pits continuously acknowledge incoming packets even though the TCP window size is reduced to zero
- Detecting presence of layer 2 tar pits
 - Look for the response with unique MAC address which act as kind of black hole
 - Need to be on the same layer 2 network
- Detecting Honeypots running on VMWare
 - Look at the IEE standards for the current range of MAC addresses assigned to VMWare Inc
- Detecting presence of Honeyd Honeypot
 - Perform time based TCP finger printing methods
- Detecting presence of user mode linux honeypot

- Analyze the files such as /proc/mounts /proc/interrupts and /proc/cmdline
- Detecting presence of Sebek based honeypots
 - Sebek logs everything that is accessed via read() before transferring to the network causing congesting effect Analyze congestion in the network layer
- Detecting presence of snort inline honeypot
 - Analyze outgoing packets by capturing Snort_inline modified packet through another host system and identifying the packet Modification
- Detecting presence of fake AP
 - Fake access points only send beacon frames but do not generate any fake traffic on the access points and an attacker can monitor the network traffic and easily notice the presence of fake AP
- Detecting presence of bait and switch honeypots
 - Look at specific TCP/IP parameters like round trip time, TTL, and the TCP timestamp



Send Safe Honeypot Hunter

- Tool designed for checking lists of HTTPS and SOCKS proxies for Honey pots

IDS Firewall Evasion Countermeasures

1 Shut down switch ports associated with known attack hosts	8 Ensure that the IDS normalizes fragmented packets and allows those packets to be reassembled in the proper order
2 Perform an in-depth analysis of ambiguous network traffic for all possible threats	9 Define DNS server for client resolver in routers or similar network devices
3 Use TCP FIN or a Reset (RST) packet to terminate malicious TCP sessions	10 Harden the security of all communication devices such as modems and routers
4 Look for the a nop opcode other than 0x90 to defend against the polymorphic shellcode problem	11 If possible, block ICMP TTL expired packets at the external interface level and change the TTL field to a large value
5 Train users to identify attack patterns and regularly update/patch all the systems and network devices	12 Regularly update the antivirus signature database
6 Deploy IDS after a thorough analysis of the network topology, nature of network traffic, and number of hosts to monitor	13 Use a traffic normalization solution at the IDS to protect the system against evasions
7 Use a traffic normalizer to remove potential ambiguity from the packet stream before it reaches the IDS	14 Store the attack information (attacker IP, victim IP, timestamp, etc.) for future analysis

- Shutdown switch ports
- Perform in depth analysis of ambiguous network traffic
- Use TCP FIN or RST packet to terminate malicious TCP sessions
- Look for code other than 0x90 to defend against polymorphic shellcode
- Train users to identify attack patterns and regularly update/ patch
- Deploy IDS after a through analysis of network topology nature of network traffic and the number of host to monitor
- Use a traffic normalizer to remove potential ambiguity from packet stream before it reaches IDS
- Ensure IDS normalize fragmented packets and allows those packets to be reassembled In the proper order
- Define DNS server for client resolver in routers or similar network devices
- Harden the security of all communication devices such as modems, routers, switches, etc
- Block ICMP TTL expired packets

- Update antivirus signature regularly
- Use a traffic normalization solution at the IDS to prevent the system against evasion
- Store the attack information for future analysis

Social Engineering

- The art of manipulating a person or group into providing information or a service they would otherwise not have given
- Phases
 - Research (dumpster dive, visit websites, tour the company, etc.)
 - Select the victim (identify frustrated employee or other target)
 - Develop a relationship iv. Exploit the relationship (collect sensitive information)
- Reasons This Works
 - Human nature (trusting others)
 - Ignorance of social engineering efforts
 - Fear (of consequences of not providing the information)
 - Greed (promised gain for providing requested information)
 - A sense of moral obligation

Human-Based Attacks

- Dumpster Diving
 - looking for sensitive information in the trash
 - Shredded papers can sometimes indicate sensitive info
- Impersonation

- pretending to be someone you're not
 - Can be anything from a help desk person up to an authoritative figure (FBI agent)
 - Posing as a tech support professional can really quickly gain trust with a person
- Shoulder Surfing
 - looking over someone's shoulder to get info
 - Can be done long distance with binoculars, etc.
- Eavesdropping
 - listening in on conversations about sensitive information
- Tailgating - attacker has a fake badge and walks in behind someone who has a valid one
- Piggybacking - attacker pretends they lost their badge and asks someone to hold the door
- RFID Identity Theft (RFID skimming) - stealing an RFID card signature with a specialized device
- Reverse Social Engineering - getting someone to call you and give information
 - Often happens with tech support - an email is sent to user stating they need them to call back (due to technical issue) and the user calls back
- Can also be combined with a DoS attack to cause a problem that the user would need to call about
- Always be pleasant - it gets more information
- Rebecca or Jessica - targets for social engineering
- Insider Attack - an attack from an employee, generally disgruntled
 - Sometimes subclassified (negligent insider, professional insider)

Computer-Based Attacks

- Can begin with sites like Facebook where information about a person is available

- For instance - if you know Bob is working on a project, an email crafted to him about that project would seem quite normal if you spoof it from a person on his project
- Phishing - crafting an email that appears legitimate but contains links to fake websites or to download malicious content
- Ways to Avoid Phishing
 - Beware unknown, unexpected or suspicious originators
 - Beware of who the email is addressed to
 - Verify phone numbers
 - Beware bad spelling or grammar
 - Always check links
- Spear Phishing - targeting a person or a group with a phishing attack
 - Can be more useful because attack can be targeted
- Whaling - going after CEOs or other C-level executives
- Pharming - use of malicious code that redirects a user's traffic
- Spimming - sending spam over instant message
- Tools - Netcraft Toolbar and PhishTank Toolbar
- Fave Antivirus - very prevalent attack; pretends to be an anti-virus but is a malicious tool

Mobile-Based Attacks

- ZitMo (ZeuS-in-the-Mobile) - banking malware that was ported to Android
- SMS messages can be sent to request premium services
- Attacks
 - Publishing malicious apps Repackaging legitimate apps
 - Fake security applications

- SMS (smishing)

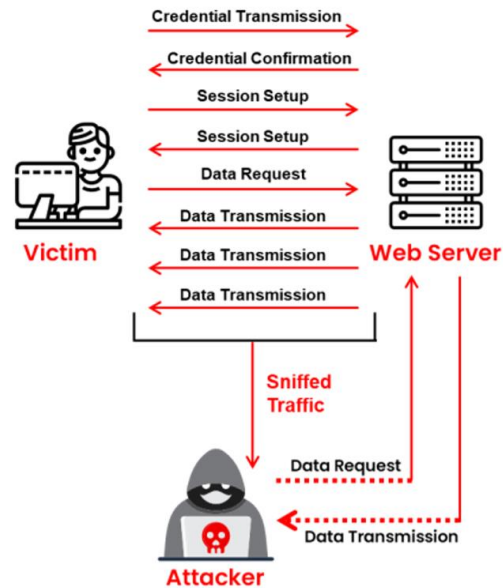
Physical Security Basics

- Physical measures - everything you can touch, taste, smell or get shocked by o Includes things like air quality, power concerns, humidity-control systems
- Technical measures - smartcards and biometrics
- Operational measures - policies and procedures you set up to enforce a securityminded operation
- Access controls - physical measures designed to prevent access to controlled areas
 - Biometrics - measures taken for authentication that come from the "something you are" concept
 - ❖ False rejection rate (FRR) - when a biometric rejects a valid user
 - ❖ False acceptance rate (FAR) - when a biometric accepts an invalid user
 - ❖ Crossover error rate (CER) - combination of the two; determines how good a system is
- Even though hackers normally don't worry about environmental disasters, this is something to think of from a pen test standpoint (hurricanes, tornados, floods, etc.)

Session Hijacking Concepts

- Refers to an attack where an attacker takes over a valid TCP communication session between two computers
- Can be used to perform identity theft and fraud
- Steals a valid session ID and uses it for themselves
- Why Successful
 - No lockout for invalid session ids o Weak generation algorithm o

- Insecure handling of IDs
 - Indefinite session
 - Most computers are vulnerable
 - Most countermeasures do not work unless you use encryption
- Process
 - Sniff
 - Monitor
 - Session Desync
 - Session ID prediction
 - Command injection
- Types of session hijacking
 - Active - attack is when an attacker takes over an active session
 - Passive - attack is when an attack hijacks a session but just watches the information sent
- Network level hijacking - is the interception of the packets
- Application-level hijacking - is gaining control of a user's http session by getting a session ID

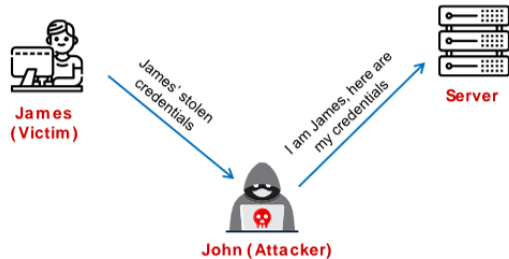


Spoofing vs Hijacking

- Spoofing
 - Attackers pretend to be another user or machine
 - Attackers do not take over an existing session using stolen creds to start new session
- Hijacking
 - Taking over an existing session
 - Relies on a legitimate user to start the session and authenticate

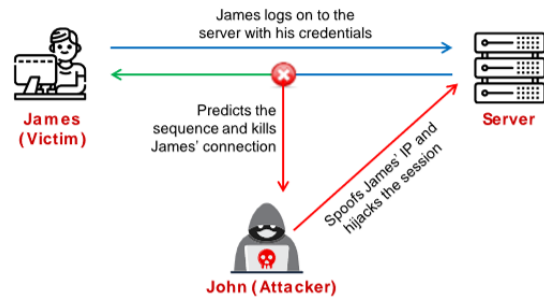
Spoofing Attack

- An attacker **pretends to be another user** or machine (victim) to gain access
- The attacker does not seize control of an existing active session; instead, he or she initiates a new session using the victim's **stolen credentials**



Hijacking

- Session hijacking is the process of seizing control of an **existing active session**
- The attacker relies on the **legitimate user** to create a connection and authenticate



Application-level session Hijacking

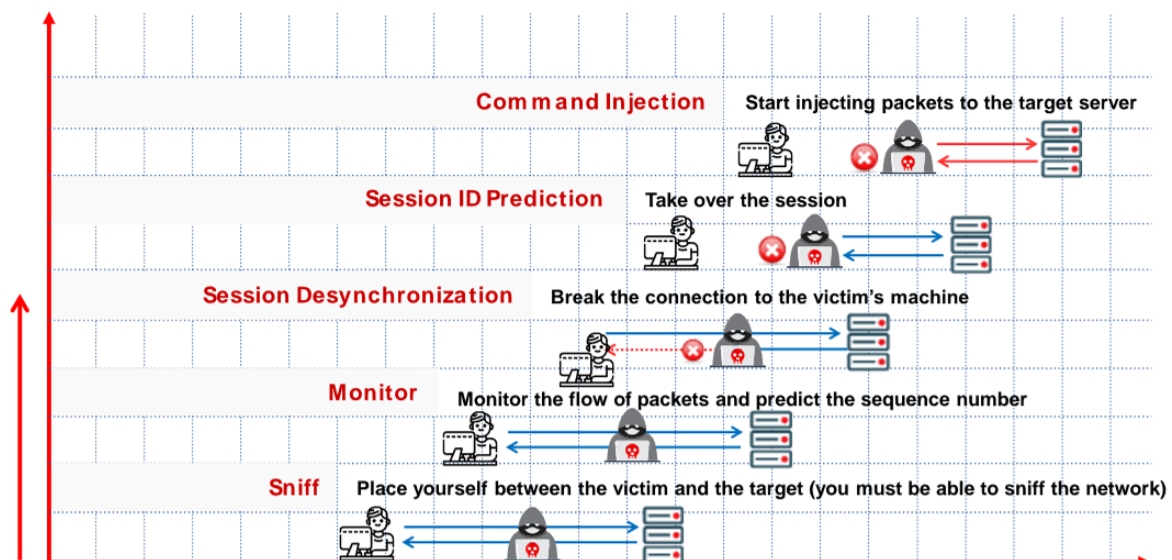
- Token Compromised by
 - Session sniffing
 - Man in the middle attack
 - Cross site scripting
 - Session replay attack
 - CRIME attack
 - Predictable session token
 - Man in the browser attack
 - Cross site request for forgery attack
 - Session fixation attack
 - Forbidden attack
- Compromising session ID using sniffing
 - Capture valid session token or ID using sniffer
 - Uses session ID to gain unauthorized access

- Compromising session ID by predicting session token
 - Predict session ID generated by weak algorithm and impersonate a web site user
 - Attack studies the session variables to determine common patterns o Can be done manually or by using crypto analytic tools
 - Involves collecting a high number of simultaneous session IDs to keep the variables constant
 - Most web servers use custom algorithms or predefined patterns to generate session IDs
 - Attacker is then able to figure out the algorithm to guess the session IDs
- Compromising sessions using Man in the middle
 - Get into the middle of communication between the user and the server
 - Involves splitting the TCP connection into two connections
 - ❖ Client to attacker
 - ❖ Attacker to server o
 - Attackers can then add fraudulent data into the intercepted communications o In the case of http the connection between the client and the server becomes the connection between the client and the attacker
- Compromising IDs using man in the browser
 - Man in the browser attacks use trojans to intercept the connection between the browser and its security libraries
 - Steps to perform a man in the browser attack:
 - ❖ Trojan infects the computer software
 - ❖ Trojan saves malicious code to the browser config
 - ❖ Browser is restarted and the malicious code loads as an extension
 - ❖ Extension file registers a handler for every site visited

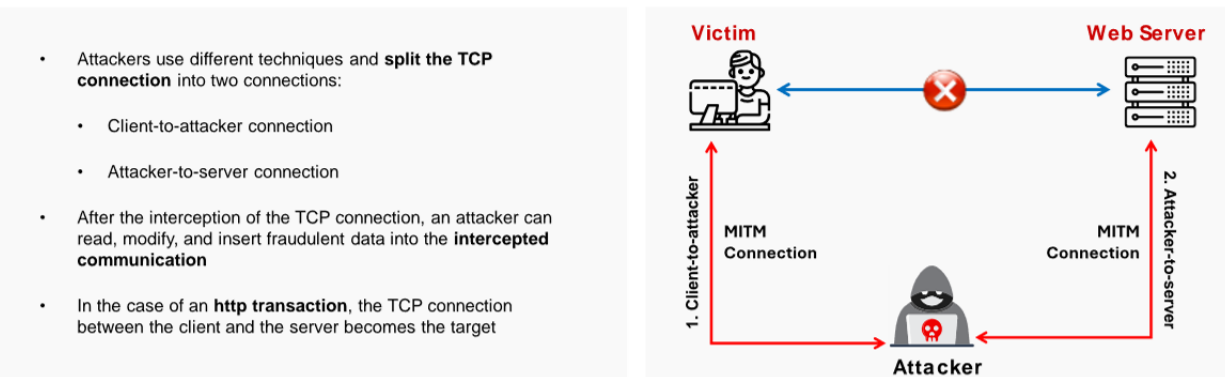
- ❖ When a page is loading the extension checks it to a list of target sites
- ❖ User logs into the site
- ❖ Registers a button event handler
- ❖ Extension uses the DOM interface to extract all the info entered fields on a site
- ❖ The browser sends the form and modified values to the server
- ❖ The server cannot tell the values were modified
- ❖ Server performs the transaction and a receipt is generated
- ❖ The browser then displays the receipt with the original info from the user
- ❖ The user thinks the original transaction was received
- Compromising ID using client-side attacks
 - XSS enables attackers to inject malicious client-side scripts into webpages
 - Malicious JavaScript can be embedded into a webpage and capture session
- IDs
 - Trojans change the proxy server to send all sessions to the attacker
- Cross site request forgery attack (CSRF) attack exploits a victim's active session with a trusted site in order to perform malicious activities
 - Attackers make site with malicious link or image on website
 - Users gets legitimate session with legitimate website
 - User clicks malicious link and gets the users session ID to gain access to the legitimate website
- Session replay – Attack listens to the conversation between the user and the server and captures the session token the attacker then replays the request to the server with the captured token and gains access to the server

- Session Fixation
 - Allows an attacker to hijack a valid user session
 - Attacker gets a user's to authenticate with a known session ID and then Hijacks the session with the known session ID
 - The attack has to provide a legitimate session ID and then get the user to use it
 - Techniques:
 - ❖ Session token in URL argument
 - ❖ Session Token in a hidden form field
 - ❖ Session ID in a cookie
- Session hijacking using proxy servers
 - Proxy servers act as an intermediary for the session and due all the interaction for the session for the users
 - Therefor the proxy server has control over the session

Session Hijacking Process



The man-in-the-middle/manipulator-in-the-middle attack is used to **intrude into an existing connection** between systems and intercept the messages being exchanged

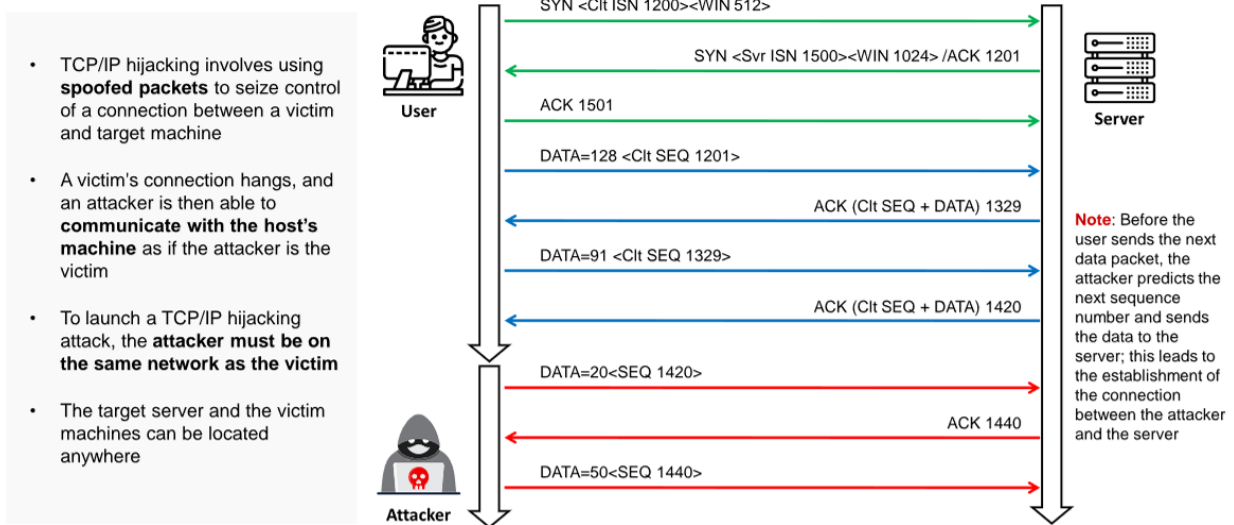


Network Level Session Hijacking

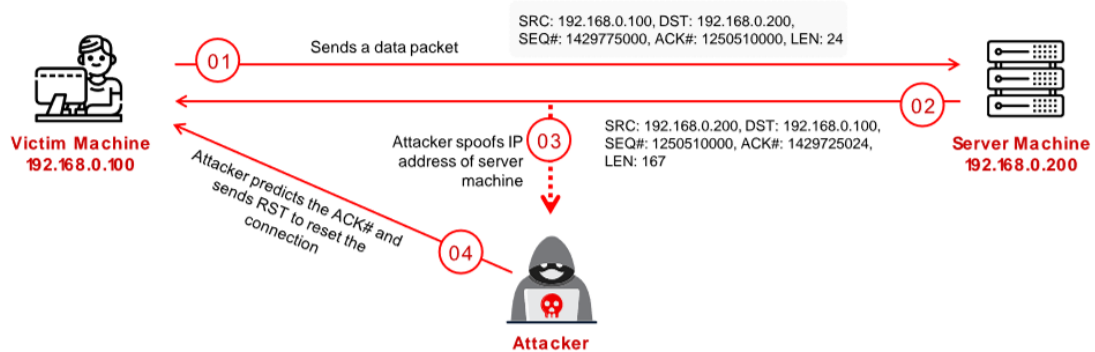
- Network level hijacking relies on hijacking the transport and internet protocols used
- by the web application in the application layer
- Type of attacks
 - Blind hijacking
 - UDP hijacking
 - TCP/IP hijacking
 - RST hijacking
 - Man in the middle packet sniffers
 - IP spoofing of source routed packets
- TCP/IP hijacking - uses spoofed packets to take over the connection between the victim and target
 - Attacker must be on the same network as the victim
- IP Spoofing source routed packets
 - Used to gain access to a computer with the help of a trusted host
 - The attacker spoofs the host's ip address so that the server managing the session with the host accepts the packet

- When the session is established, the attacker injects forged packets before the host responds to the server
- The original packets are lost since the attacker has already used the sequence numbers of those packets
- The packets from the attacker are source routed through the host with the destination ip specified by the attacker
- RST Hijacking
 - Involves injecting an authentic looking reset packet using spoofed addresses
 - The attacker can reset the session if he uses an accurate acknowledgment number
 - The victim believes the source actually reset the connection
- Blind Hijacking
 - The attacker can send data or commands but since source routing is disabled the attacker has no access to the response
- UDP Hijacking
 - Sends forged replies to the victim before the server does
- MiTM attack using ICMP and Arp Spoofing
 - Packet sniffer used as an interface between the client and the server
 - ARP spoofing involves fooling the host by changing the arp table with fake arp request
 - ICMP spoofing involves sending fake error messages
- Session Hijacking tools
 - Burp Suite
- Countermeasures
 - Uses SSH

- Implement logout functionality
- Generate session IDs after user login and only accept session IDs generated by server
- Encrypt all data
- Uses strings or long random numbers for session ids
- Uses different username and password for different accounts Implement a timeout
- Don't transport session ids in query string
- Ensure protective software is working
- Strong authentication like Kerberos

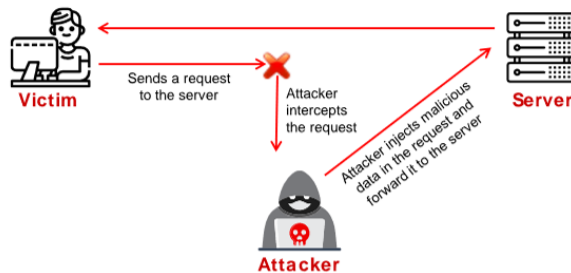


- RST hijacking involves injecting an **authentic-looking reset (RST) packet** using a spoofed source address and predicting the acknowledgment number
- A hacker can reset a victim's connection if it uses an **accurate acknowledgment number**
- The victim would believe that the source sent the **reset packet**, and **reset the connection**
- RST Hijacking can be performed using a **packet crafting tool**, such as Colasoft Packet Builder, and TCP/IP analysis tools, such as tcpdump



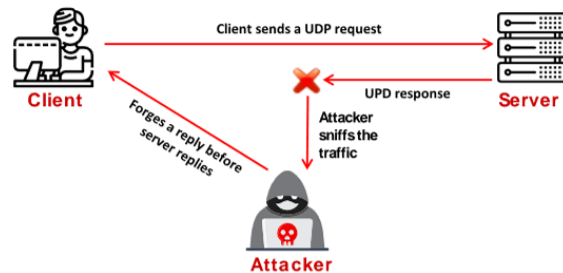
Blind Hijacking

- An attacker can inject **malicious data or commands** into the intercepted communications in the TCP session even if the source-routing is disabled
- The attacker can send the data or commands but has no **access to see the response**



UDP Hijacking

- A network-level session hijacking where the attacker sends **forged server reply** to a victim's UDP request before the intended server replies to it
- The attacker uses a **man-in-the-middle** attack to intercept the server's response to the client and sends a forged reply



Protecting against Session Hijacking

- | | |
|---|--|
| 01 Use Secure Shell (SSH) or OpenSSH to create a secure communication channel | 08 Avoid including the session ID in the URL or query string |
| 02 Implement the log-out functionality for the user to end the session | 09 Ensure that client-side and server-side protection software are in the active state and up-to-date |
| 03 Generate a session ID after a successful login and accept only session IDs generated by the server only | 10 Use strong authentication (such as Kerberos) or peer-to-peer virtual private networks (VPNs) |
| 04 Ensure that data in transit is encrypted and implement the defense-in-depth mechanism | 11 Configure appropriate internal and external spoof rules on gateways |
| 05 Use string or long random numbers as session keys | 12 Use IDS products or ARPwatch for monitoring ARP cache poisoning |
| 06 Switch from a hub network to a switch network to reduce the risk of session hijacking attacks | 13 Enable browsers to verify website authenticity using network notary servers |
| 07 Implement timeout() to destroy sessions when expired | 14 Use SFTP, AS2 managed file transfer, or FTPS to send data using encryption and digital certificates |

Denial of Service Attacks

- Seeks to take down a system or deny access to it by authorized users
- Botnet - network of zombie computers a hacker uses to start a distributed attack can be controlled over HTTP, HTTPS, IRC, or ICQ
- Basic Categories
 - Fragmentation attacks - attacks take advantage of the system's ability to reconstruct fragmented packets
 - Volumetric attacks - bandwidth attacks; consume all bandwidth for the system or service
 - Application attacks - consume the resources necessary for the application to run (note - application-level attacks are against weak code; application attacks are just the general term)
 - TCP state-exhaustion attacks - go after load balancers, firewalls and application servers
 - SYN attack - sends thousands of SYN packets to the machine with a false source address; eventually engages all resources and exhausts the machine

- SYN flood - sends thousands of SYN packets; does not spoof IP but doesn't respond to the SYN/ACK packets; eventually bogs down the computer, runs out of resources
- ICMP flood - sends ICMP Echo packets with a spoofed address; eventually reaches the limit of packets per second sent
- Smurf - large number of pings to the broadcast address of the subnet with source IP spoofed as the target; entire subnet responds exhausting the target
- Fraggle - same as smurf but with UDP packets
- Ping of Death - fragments ICMP messages; after reassembled, the ICMP packet is larger than the maximum size and crashes the system
- Teardrop - overlaps a large number of garbled IP fragments with oversized payloads; causes older systems to crash due to fragment reassembly
- Peer to peer - clients of peer-to-peer file-sharing hub are disconnected and directed to connect to the target system
- Phlashing - a DoS attack that causes permanent damage to a system; also called bricking a system
- LAND attack - sends a SYN packet to the target with a spoofed IP the same as the target; if vulnerable, target loops endlessly and crashes
- Low Orbit Ion Cannon (LOIC) - DDoS tool that floods a target with TCP, UDP or HTTP requests
- Other Tools
 - Trinity - Linux based DDoS tool
 - Tribe Flood Network - uses voluntary botnet systems to launch massive flood attacks
 - R-U-Dead-Yet (RUDY) - DoS with HTTP POST via long-form field submissions

6 Reconnaissance Techniques

Number of Questions - 26

Sub Domain/Description

- Footprinting and Reconnaissance
 - Footprinting Concepts
 - Footprinting Methodology
 - Footprinting through Search Engines
 - Footprinting through Web Services
 - Footprinting through Social Networking Sites
 - Website Footprinting
 - Email Footprinting
 - Whois Footprinting
 - DNS Footprinting
 - Network Footprinting
 - Footprinting through Social Engineering
 - Footprinting Tools
 - Footprinting Countermeasures
- Scanning Networks
 - Network Scanning Concepts
 - Scanning Tools
 - Host Discovery
 - Port and Service Discovery
 - OS Discovery (Banner Grabbing/OS

- Fingerprinting)
- Scanning Beyond IDS and Firewall
- Network Scanning Countermeasures
- Enumeration
 - Enumeration Concepts
 - NetBIOS Enumeration
 - SNMP Enumeration
 - LDAP Enumeration
 - NTP and NFS Enumeration
 - SMTP and DNS Enumeration
 - Other Enumeration Techniques (IPsec, VoIP, RPC, Unix/Linux, Telnet, FTP, TFTP, SMB, IPv6, and BGP enumeration)
 - Enumeration Countermeasures

Footprinting

- Looking for high-level information on a target
- Types:
 - Anonymous - information gathering without revealing anything about yourself
 - Pseudonymous - making someone else take the blame for your actions

Four Main Focuses

- Know the security posture
- Reduce the focus area

- Identify vulnerabilities
- Draw a network map

Types of Footprinting

- Active - requires attacker to touch the device or network
 - Social engineering and other communication that requires interaction with target
- Passive - measures to collect information from publicly available sources
 - Websites, DNS records, business information databases

***Competitive Intelligence - information gathered by businesses about competitors

***alexa.com - resource for statistics about websites

Search Engines

- NetCraft - information about website and possibly OS info
- Job Search Sites - information about technologies can be gleaned from job postings
- Google
 - filetype: - looks for file types
 - index of – directory listings
 - info: - contains Google's information about the page
 - intitle: - string in title
 - inurl: - string in url
 - link: - finds linked pages
 - related: - finds similar pages

- site: - finds pages specific to that site
- Metagoofil - uses Google hacks to find information in meta tags

Website Footprinting

- Web mirroring - allows for discrete testing offline
 - HTTrack
 - Black Widow
 - Wget
 - WebRipper
 - Teleport Pro
 - Backstreet Browser
- Archive.org - provides cached websites from various dates which possibly have sensitive information that has been now removed

Email Footprinting

- Email header - may show servers and where the location of those servers is
- Email tracking - services can track various bits of information including the IP address of where it was opened, where it went, etc.

DNS Footprinting

- Ports
 - Name lookup - UDP 53
 - Zone transfer - TCP 53

- Zone transfer replicates all records
- Name resolvers answer requests
- Authoritative Servers hold all records for a namespace

DNS Record Types

Record Type	Name	Description
A	Address (IPv4)	Maps a domain name to an IPv4 address
AAAA	Address (IPv6)	Maps a domain name to an IPv6 address
CNAME	Canonical Name	Maps an alias or subdomain to the canonical domain name. It is used to associate multiple domain names with a single IP address or hostname.
NS	Name Server	Specifies the authoritative name servers for a domain. It identifies the DNS servers responsible for a specific domain.
SOA	Start Of Authority	Provides information about the authoritative name server for a domain. It includes details such as the primary name server for the domain, the email address of the responsible person, and various timers.
MX	Mail Exchange	Specifies the mail server responsible for handling email messages for a domain. It identifies the hostname of the mail server that should receive email messages for a specific domain.
SRV	Service	Specifies the location of services in a domain. It is used to define the location of servers for specific protocols, such as SIP (VoIP)
TXT	Text	Contains arbitrary text information. It is often used for verification purposes, such as domain ownership verification or email authentication.

A	Maps a domain name to an IPv4 address E.g. my.com → 192.168.0.2	PTR	Shows reverse DNS lookup info for an IP address E.g. 192.168.0.2 → my.com
AAAA	Maps a domain name to an IPv6 address E.g. my.com → 2001:db8::1	TXT	Allows admins to add any text info for verification E.g. sender policy info
CNAME	Maps an alias name to a canonical domain name E.g. www.my.com → my.com	SRV	Specifies info about available services in a domain E.g. SIP server host/port info
MX	Specifies mail exchange servers for a domain E.g. mail.my.com	SOA	Stores essential domain info E.g. primary domain server, admin email, domain serial #
NS	Indicates DNS servers for a domain E.g. my.com NS ns1.my.com	CAA	Specifies which certificate authorities are allowed to issue certificates for a domain

- DNS Poisoning - changes cache on a machine to redirect requests to a malicious server

- DNSSEC - helps prevent DNS poisoning by encrypting records
- SOA Record Fields
 - Source Host - hostname of the primary DNS
 - Contact Email - email for the person responsible for the zone file
 - Serial Number - revision number that increments with each change
 - Refresh Time - time in which an update should occur
 - Retry Time - time that an NS should wait on a failure
 - Expire Time - time in which a zone transfer is allowed to complete
 - TTL – minimum TTL for records within the zone
- IP Address Management
 - ARIN - North America
 - APNIC – Asia Pacific
 - RIPE - Europe, Middle East
 - LACNIC - Latin America
 - AfriNIC Africa
- Whois - obtains registration information for the domain
- Nslookup - performs DNS queries
- Dig - unix-based command like nslookup
 - dig @server name type

Network Footprinting

- IP address range can be obtained from regional registrar (ARIN here)
- Use traceroute to find intermediary servers

- traceroute uses ICMP echo in Windows
- Windows command - tracert
- Linux Command - traceroute

Other Tools

- OSRFramework - uses open-source intelligence to get information about target
- Web Spiders - obtain information from the website such as pages, etc.
- Social Engineering Tools
 - Maltego
 - Social Engineering Framework (SEF)
- Shodan - search engine that shows devices connected to the Internet

Computer Security Incident Response Team (CSIRT) - point of contact for all incident response services for associates of the DHS

TCP Flags

Flag	Name	Function
SYN	Synchronize	Set during initial communication. Negotiating of parameters and sequence numbers
ACK	Acknowledgment	Set as an acknowledgement to the SYN flag. Always set after initial SYN
RST	Reset	Forces the termination of a connection (in both directions)
FIN	Finish	Ordered close to communications

Flag	Name	Function
PSH	Push	Forces the delivery of data without concern for buffering
URG	Urgent	Data inside is being sent out of the band. Example is cancelling a message

Subnetting

- IPv4 Main Address Types
 - Unicast - acted on by a single recipient
 - Multicast - acted on by members of a specific group
 - Broadcast - acted on by everyone on the network
 - ❖ Limited - delivered to every system in the domain (255.255.255.255)
 - ❖ Directed - delivered to all devices on a subnet and use that broadcast address
- Subnet mask - determines how many address available on a specific subnet .
Represented by three methods
 - Decimal - 255.240.0.0
 - Binary - 11111111.11110000.00000000.00000000
 - CIDR - x.x.x.x/12 (where x.x.x.x is an ip address on that range)
 - If all the bits in the host field are 1s, the address is the broadcast
 - If they are all 0s, it's the network address
 - Any other combination indicates an address in the range

Scanning Methodology

- Check for live systems - ping or other type of way to determine live hosts
- Check for open ports - once you know live host IPs, scan them for listening ports
- Scan beyond IDS - if needed, use methods to scan beyond the detection systems
- Perform banner grabbing - grab from servers as well as perform OS fingerprinting
- Scan for vulnerabilities - use tools to look at the vulnerabilities of open systems
- Draw network diagrams - shows logical and physical pathways into networks
- Prepare proxies - obscures efforts to keep you hidden

Identifying Targets

- The easiest way to scan for live systems is through ICMP.
- It has its shortcomings and is sometimes blocked on hosts that are actually live.
- Ping sweep - easiest method to identify hosts
- ICMP Echo scanning - sending an ICMP Echo Request to the network IP address
- An ICMP return of type 3 with a code of 13 indicates a poorly configured firewall
- Ping scanning tools
 - Nmap
 - Angry IP Scanner
 - Solar-Winds Engineer Toolkit
 - Advanced IP Scanner
 - Pinkie
 - Nmap virtually always does a ping sweep with scans unless you turn it off

Port Scan Types

- Full connect - TCP connect or full open scan - full connection and then tears down with RST
 - Easiest to detect, but most reliable
 - `nmap -sT`
- Stealth - half-open scan or SYN scan - only SYN packets sent. Responses same as full.
 - Useful for hiding efforts and evading firewalls
 - `nmap -sS`
- Inverse TCP flag - uses FIN, URG or PSH flag. Open gives no response. Closed gives RST/ACK
 - `nmap -sN` (Null scan)
 - `nmap -sF` (FIN scan)
- Xmas - so named because all flags are turned on so it's "lit up" like a Christmas tree
 - Responses are same as Inverse TCP scan
 - Do not work against Windows machines
 - `nmap -sX`
- ACK flag probe - multiple methods
 - TTL version - if TTL of RST packet < 64, port is open
 - Window version - if the Window on the RST packet is anything other than 0, port open
 - Can be used to check filtering. If ACK is sent and no response, stateful firewall present.
 - `nmap -sA` (ACK scan) o `nmap -sW` (Window scan)

- IDLE Scan - uses a third party to check if a port is open
 - o Looks at the IPID to see if there is a response
 - o Only works if third party isn't transmitting data
 - o Sends a request to the third party to check IPID id; then sends a spoofed packet to the target with a return of the third party; sends a request to the third party again to check if IPID increased.
 - ❖ IPID increase of 1 indicates port closed
 - ❖ IPID increase of 2 indicates port open
 - ❖ IPID increase of anything greater indicates the third party was not
 - o idle o nmap -sl

Nmap Switches

Switch	Description
-sA	ACK scan
-sF	FIN scan
-sl	IDLE scan
-sR	RPC scan
-sL	DNS scan (list scan)
-sP	Ping scan
-sP	Ping scan
-sO	Protocol scan (tests which IP protocols respond)
-sN	NULL scan
-sS	SYN scan
-sW	Window scan

Switch	Description
-sT	TCP connect scan
-sX	XMAS scan
-A	OS detection, version detection, script scanning and traceroute
-PI	ICMP ping
-Po	No ping
-oN	Normal output
-PS	SYN ping
-PT	TCP ping
-oX	XML output
-T3 through -T5 Parallel scans	T3 is slowest (Nmap runs by default at a T3 level)
-T0 through -T2 Serial scans	T0 is slowest

Hping

- Another powerful ping sweep and port scanning tool
- Also can craft packets
- hping3 -1 IPAddress

HPING Switch

Switch	Description
-1	Sets ICMP mode

Switch	Description
-2	Sets UDP mode
-8	Sets scan mode. Expects port range without -p flag
-9	Listen mode. Expects signature (e.g. HTTP) and interface (-I eth0)
--flood	Sends packets as fast as possible without showing incoming replies
-Q	Collects sequence numbers generated by the host
-p	Sets port number
-F	Sets the FIN flag
-S	Sets the SYN flag
-R	Sets the RST flag
-P	Sets the PSH flag
-A	Sets the ACK flag
-U	Sets the URG flag
-X	Sets the XMAS scan flags

Evasion

- To evade IDS, sometimes you need to change the way you scan
- One method is to fragment packets (nmap -f switch)
- OS Fingerprinting
 - Active - sending crafted packets to the target
 - Passive - sniffing network traffic for things such as TTL windows, DF flags and ToS fields
- Spoofing - can only be used when you don't expect a response back to your machine

- Source routing - specifies the path a packet should take on the network; most systems don't allow this anymore
- IP Address Decoy - sends packets from your IP as well as multiple other decoys to confuse the IDS/Firewall as to where the attack is really coming from
 - `nmap -D RND:10 x.x.x.x`
 - `nmap -D decoyIP1,decoyIP2...,sourceIP,... [target]`
- Proxy - hides identity by filtering through another computer. Also, can be used for other purposes such as content blocking evasion, etc.
 - Proxy chains - chaining multiple proxies together
 - Proxy Switcher
 - Proxy Workbench
 - ProxyChains
- Tor - a specific type of proxy that uses multiple hops to a destination; endpoints are peer computers
- Anonymizers - hides identity on HTTP traffic (port 80)

Banner Grabbing

- Active - sending specially crafted packets and comparing responses to determine OS
- Passive - reading error messages, sniffing traffic or looking at page extensions
- Easy way to banner grab is connect via telnet on port (e.g. 80 for web server)
- Netcat can also be used to banner grab
- Can be used to get information about OS or specific server info (such as web server, mail server, etc.)

NetBIOS Enumeration

- NetBIOS provides name servicing, connectionless communication and some Session layer stuff
- The browser service in Windows is designed to host information about all machines within domain or TCP/IP network segment
- NetBIOS name is a 16-character ASCII string used to identify devices
- Command on Windows is nbtstat
 - nbtstat (gives your own info)
 - nbtstat -n (gives local table)
 - nbtstat -A IPADDRESS (gives remote information)
 - nbtstat -c (gives cache information)

Code	Type	Meaning
<1B>	UNIQUE	Domain master browser
<1C>	UNIQUE	Domain controller
<1D>	GROUP	Master browser for subnet
<00>	UNIQUE	Hostname
<00>	GROUP	Domain name
<03>	UNIQUE	Service running on system
<20>	UNIQUE	Server service running

***NetBIOS name resolution doesn't work on IPv6

***Other Tools

- SuperScan

- Hyena
- NetBIOS Enumerator
- NSAuditor

SNMP Enumeration

- Management Information Base (MIB) - database that stores information
- Object Identifiers (OID) - identifiers for information stored in MIB
- SNMP GET - gets information about the system
- SNMP SET - sets information about the system
- Types of objects
 - Scalar - single object
 - Tabular - multiple related objects that can be grouped together
- SNMP uses community strings which function as passwords
- There is a read-only and a read-write version
- Default read-only string is public and default read-write is private
- These are sent in cleartext unless using SNMP v3
- Tools
 - Engineer's Toolset
 - SNMPScanner
 - OpUtils 5
 - SNScan

Other Enumerations

- LDAP

- Connects on 389 to a Directory System Agent (DSA)
- Returns information such as valid usernames, domain information, addresses, telephone numbers, system data, organization structure and other items
- Tools:
 - ❖ Softerra
 - ❖ JXplorer
 - ❖ Lex
 - ❖ LDAP Admin Tool
- NTP
 - Runs on UDP 123 o Querying can give you list of systems connected to the server (name and IP)
 - Tools:
 - ❖ NTP Server Scanner
 - ❖ AtomSync
 - ❖ ntptrace, ntpdc and ntpq
- SMTP
 - VRFY - validates user
 - EXPN - provides actual delivery address of mailing list and aliases
 - RCPT TO - defines recipients

Protocols Susceptible

- SMTP is sent in plain text and is viewable over the wire. SMTP v3 limits the information you can get, but you can still see it.
- FTP sends user ID and password in clear text

- TFTP passes everything in clear text
- IMAP, POP3, NNTP and HTTP all send over clear text data
- TCP shows sequence numbers (usable in session hijacking)
- TCP and UCP show open ports
- IP shows source and destination addresses

IPv6

- Uses 128-bit address
- Has eight groups of four hexadecimal digits
- Sections with all 0s can be shorted to nothing (just has start and end colons)
- Double colon can only be used once
- Loopback address is ::1

Wiretapping

- Lawful interception - legally intercepting communications between two parties
- Active - interjecting something into communication
- Passive - only monitors and records the data
- PRISM - system used by NSA to wiretap external data coming into US

Active and Passive Sniffing

- Passive sniffing - watching network traffic without interaction; only works for same collision domain

- Active sniffing - uses methods to make a switch send traffic to you even though it isn't destined for your machine
- Span port - switch configuration that makes the switch send a copy of all frames from other ports to a specific port
 - Not all switches could do this
 - Modern switches sometimes don't allow span ports to send data - you can only listen
- Network tap - special port on a switch that allows the connected device to see all traffic
- Port mirroring - another word for span port

MAC Flooding

- Switches either flood or forward data If a switch doesn't know what MAC address is on a port, it will flood the data until it finds out
- CAM Table - the table on a switch that stores which MAC address is on which port
 - If table is empty or full, everything is sent to all ports
- This works by sending so many MAC addresses to the CAM table that it can't keep up
- Tools
 - Etherflood
 - Macof
- Switch port stealing - try to update information regarding a specific port in a race condition
- MAC Flooding will often destroy the switch before you get anything useful, doesn't last long and it will get you noticed. Also, most modern switches protect against this.

ARP Poisioning

- Also called ARP spoofing or gratuitous ARP
- This can trigger alerts because of the constant need to keep updating the ARP cache of machines
- Changes the cache of machines so that packets are sent to you instead of the intended target
- Countermeasures
 - Dynamic ARP Inspection using DHCP snooping
 - XArp can also watch for this
 - Default gateway MAC can also be added permanently into each machine's cache
- Tools o Cain and Abel
 - WinArpAttacker
 - Ufasoft
 - dsniff

DHCP Starvation

- Attempt to exhaust all available addresses from the server
- Attacker sends so many requests that the address space allocated is exhausted
- DHCPv4 packets - DHCPDISCOVER, DHCPOFFER, DHCPREQUEST, DHCPACK
- DHCPv6 packets - Solicit, Advertise, Request (Confirm/Renew), Reply
- DHCP Steps:
 - ❖ Client sends DHCPDISCOVER
 - ❖ Server responds with DHCPOFFER

- ❖ Client sends request for IP with DHCPREQUEST iv. Server sends address and config via DHCPACK
- Tools
 - Yersinia
 - DHCPstarv
- Mitigation is to configure DHCP snooping
- Rogue DHCP Server - setup to offer addresses instead of real server. Can be combined with starvation to real server.

Spoofing

- MAC Spoofing - changes your MAC address. Benefit is CAM table uses most recent address.
- Port security can slow this down, but doesn't always stop it
- MAC Spoofing makes the switch send all packets to your address instead of the intended one until the CAM table is updated with the real address again
- IRDP Spoofing - hacker sends ICMP Router Discovery Protocol messages advertising a malicious gateway
- DNS Poisoning - changes where machines get their DNS info from, allowing attacker to redirect to malicious websites

Sniffing Tools

- Wireshark
 - Previously known as Ethereal
 - Can be used to follow streams of data

- Can also filter the packets so you can find a specific type or specific source address
- Example filters:
 - ! (arp or icmp or dns) - filters out the "noise" from ARP, DNS and ICMP requests
 - http.request - displays HTTP GET requests
 - tcp contains string - displays TCP segments that contain the word "string"
 - ip.addr==172.17.15.12 && tcp.port==23 - displays telnet packets containing that IP
 - tcp.flags==0x16 - filters TCP requests with ACK flag set
- tcpdump
 - Recent version is WinDump (for Windows)
 - Syntax:
 - tcpdump flag(s) interface
 - tcpdump -i eth1 - puts the interface in listening mode
- tcptrace
 - Analyzes files produced by packet capture programs such as Wireshark, tcpdump and Etherpeek
- Other Tools
 - Ettercap - also can be used for MITM attacks, ARP poisoning. It has active and passive sniffing.
 - Capsa Network Analyzer
 - Snort - usually discussed as an Intrusion Detection application
 - Sniff-O-Matic
 - EtherPeek

- WinDump
- WinSniffer

Evasion Techniques

- Slow down - faster scanning such as using nmap's -T5 switch will get you caught. Pros use -T1 switch to get better results
- Flood the network - trigger alerts that aren't your intended attack so that you confuse firewalls/IDS and network admins
- Fragmentation - splits up packets so that the IDS can't detect the real intent
- Unicode encoding - works with web requests - using Unicode characters instead of ascii can sometimes get past
- Tools
 - Nessus - also a vulnerability scanner
 - ADMmutate - creates scripts not recognizable by signature files
 - NIDSbench - older tool for fragmenting bits
 - Inundator - flooding tool

Firewall Evasion

- ICMP Type 3 Code 13 will show that traffic is being blocked by firewall
- ICMP Type 3 Code 3 tells you the client itself has the port closed
- Firewall type can be discerned by banner grabbing
- Firewalking - going through every port on a firewall to determine what is open
- Tools

- CovertTCP
 - ICMP Shell
 - 007 Shell
- The best way around a firewall will always be a compromised internal machine

Honeypots

- A system setup as a decoy to entice attackers
- Should not include too many open services or look too easy to attack
- High interaction - simulates all services and applications and is designed to be completely compromised
- Low interaction - simulates several services and cannot be completely compromised
- Examples
 - ❖ Specter
 - ❖ Honeyd
 - ❖ KFSensor

7 System Hacking Phases and Attack Techniques

Number of Questions – 21

Sub Domain/ Description

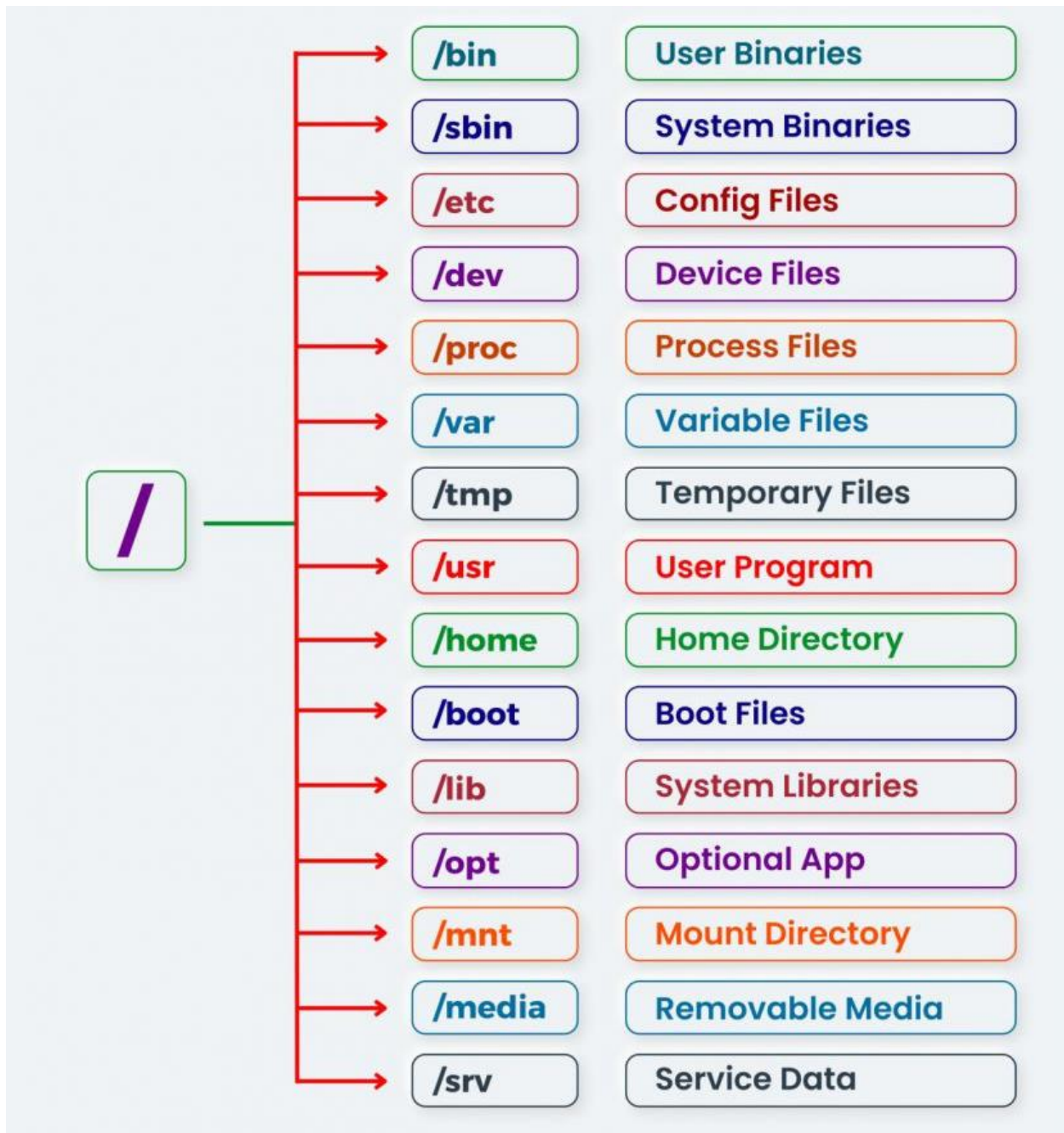
- Vulnerability Analysis
 - Vulnerability Assessment Concepts
 - Vulnerability Classification and Assessment Types
 - Vulnerability Assessment Tools
 - Vulnerability Assessment Reports
- System Hacking
 - System Hacking Concepts
 - Gaining Access
 - Password Cracking
 - Vulnerability Exploitation
 - Escalating Privileges
 - Maintaining Access
 - Executing Applications
 - Hiding Files
 - Establishing Persistence
 - Clearing Logs
- Malware Threats
 - Malware Concepts
 - APT Concepts

- Trojan Concepts
- Virus and Worm Concepts
- Fileless Malware Concepts
- Malware Analysis
- Malware Countermeasures
- Anti-Malware Software

System Hacking Goals

- Gaining Access - uses information gathered to exploit the system
- Escalating Privileges - granting the account you've hacked admin or pivoting to an admin account
- Executing Applications - putting back doors into the system so that you can maintain access
- Hiding Files - making sure the files you leave behind are not discoverable
- Covering Tracks - cleaning up everything else (log files, etc.)
 - clearev - meterpreter shell command to clear log files
 - Clear MRU list in Windows
 - In Linux, append a dot in front of a file to hide it

Linux Security Architecture



Authentication and Passwords

- Something You Are - uses biometrics to validate identity (retina, fingerprint, etc.)
 - Downside is there can be lots of false negatives

- False acceptance rate (FAR) - system accepts access for people that shouldn't have it
- False rejection rate (FRR) - system rejects access for someone who should have it
- Crossover error rate (CER) - combination of the two; the lower the CER, the better the system
- Active - requires interaction (retina scan or fingerprint scanner)
- Passive - requires no interaction (iris scan)
- Something You Have - usually consists of a token of some kind (swipe badge, ATM card, etc.)
 - This type usually requires something alongside it (such as a PIN for an ATM card)
 - Some tokens are single-factors (such as a plug-and-play authentication)
- Something You Know - better known as a password
 - Most systems use this because it is universal and well-known
- Two-Factor - when you have two types of authentications such as something you know (password) and something you have (access card)
- Strength of passwords - determined by length and complexity
 - ECC says that both should be combined for the best outcome
 - Complexity is defined by number of character sets used (lower case, upper case, numbers, symbols, etc.)
- Default passwords - always should be changed and never left what they came with. Databases such as cirt.net, default-password.info and open-sez.me all have databases of these

Password Attacks

- Non-electronic - social engineering attacks - most effective.
 - Includes shoulder surfing and dumpster diving
- Active online - done by directly communicating with the victim's machine
 - Includes dictionary and brute-force attacks, hash injections, phishing, Trojans, spyware, keyloggers and password guessing
 - Keylogging - process of using a hardware device or software application to capture keystrokes of a user
 - LLMNR/NBT-NS - attack based off Windows technologies that caches DNS locally. Responding to these poisons the local cache. If an NTLM v2 hash is sent over, it can be sniffed out and then cracked
 - Tools:
 - ❖ NBNSpoof Pupy
 - ❖ Metasploit
 - ❖ Responder
 - ❖ Hydra
- Passive online - sniffing the wire in hopes of intercepting a password in clear text or attempting a replay attack or man-in-the-middle attack
 - Tools:
 - ❖ Cain and Abel - can poison ARP and then monitor the victim's traffic
 - ❖ Ettercap - works very similarly to Cain and Abel. However, it can also help against SSL encryption
 - ❖ KerbCrack - built-in sniffer and password cracker looking for port 88 Kerberos traffic

- ❖ ScoopLM - specifically looks for Windows authentication traffic on the wire and has a password cracker
- Offline - when the hacker steals a copy of the password file and does the cracking on a separate system
 - Dictionary Attack - uses a word list to attack the password. Fastest method of attacking
 - Brute force attack - tries every combination of characters to crack a password
 - It can be faster if you know parameters (such as at least 7 characters, should have a special character, etc.)
 - Hybrid attack - Takes a dictionary attack and replaces characters or adding numbers to the end
 - Rainbow tables - uses pre-hashed passwords to compare against password hash. Is faster because the hashes are already computed.
 - Tools:
 - ❖ Cain
 - ❖ KerbCrack
 - ❖ Legion
 - ❖ John the Ripper

Privilege Escalation and Executing Applications

- Vertical - lower-level user executes code at a higher privilege level
- Horizontal - executing code at the same user level but from a location that would be protected from that access
- Four Methods

- Crack the password of an admin - primary aim
- Take advantage of an OS vulnerability
- DLL Hijacking - replacing a DLL in the application directory with your own version which gives you the access you need
- Use a tool that will provide you the access such as Metasploit. Social engineering a user to run an application
- ECC refers to executing applications as "owning" a system
- Executing applications - starting things such as keyloggers, spyware, back doors and crackers

Hiding Files and Covering Tracks

- In Windows, Alternate Data Stream (ADS) can hide files
 - Hides a file from directory listing on an NTFS file system
 - readme.txt:badfile.exe
 - Can be run by start readme.txt:badfile.exe
 - You can also create a link to this and make it look real (e.g. mklink innocent.exe readme.txt:badfile.exe)
 - To show ADS, dir /r does the trick
 - You can also blow away all ADS by copying files to a FAT partition
- You can also hide files by attributes
 - In Windows: attrib +h filename
 - In Linux, simply add a . to the beginning of the filename
- Can hide data and files with steganography
- Also need to worry about clearing logs
- ○ In Windows, you need to clear

- Option is to corrupt a log file - this happens all the time. Best option is be selective and delete the entries pertaining to your actions. Can also disable auditing ahead of time to prevent logs from being captured

Rootkits

- Software put in place by attacker to obscure system compromise. Hides processes and files. Also allows for future access
- Examples
 - Horsepill - Linus kernel rootkit inside initrd
 - Grayfish - Windows rootkit that injects in boot record
 - Firefex - multi-component family of malware
 - Azazel
 - Avatar
 - Necurs
 - ZeroAccess
- Hypervisor level - rootkits that modify the boot sequence of a host system to load a VM as the host OS
- Hardware - hide malware in devices or firmware
- Boot loader level - replace boot loader with one controlled by hacker
- Application level - directed to replace valid application files with Trojans
- Kernel level - attack boot sectors and kernel level replacing kernel code with backdoor code; most dangerous
- Library level - use system-level calls to hide themselves

***One way to detect rootkits is to map all the files on a system and then boot the system from a clean CD version and compare the two file systems

8 Web Application Hacking

Number of Questions - 20

Sub Domain/Description

- Hacking Web Servers
 - Web Server Concepts
 - Web Server Attacks
 - Web Server Attack Methodology
 - Web Server Attack Countermeasures
 - Patch Management
- Hacking Web Applications
 - Web App Concepts
 - Web App Threats
 - Web App Hacking Methodology
 - Footprint Web Infrastructure
 - Analyze Web Applications
 - Bypass Client-Side Controls
 - Attack Authentication Mechanism
 - Attack Authorization Schemes
 - Attack Access Controls
 - Attack Session Management Mechanism
 - Perform Injection/Input Validation Attacks
 - Attack Application Logic Flaws
 - Attack Shared Environments

- Attack Database Connectivity
 - Attack Web App Client
 - Attack Web Services
 - Web API, Webhooks, and Web Shell
 - Web App Security
- SQL Injection
 - SQL Injection Concepts
 - Types of SQL Injection
 - SQL Injection Methodology
 - SQL Injection Tools
 - Evasion Techniques
 - SQL Injection Countermeasure

Web Organizations

- Internet Engineering Task Force (IETF) - creates engineering documents to help make the Internet work better
- World Wide Web Consortium (W3C) - a standards-developing community
- Open Web Application Security Project (OWASP) - organization focused on improving the security of software

OWASP Web Top 10

- A1 - Injection Flaws - SQL, OS and LDAP injection

- A2 - Broken Authentication and Session Management - functions related to authentication and session management that aren't implemented correctly
- A3 - Sensitive Data Exposure - not properly protecting sensitive data (SSN, CC numbers, etc.)
- A4 - XML External Entities (XXE) - exploiting XML processors by uploading hostile content in an XML document
- A5 - Broken Access Control - having improper controls on areas that should be protected
- A6 - Security Misconfiguration - across all parts of the server and application
- A7 - Cross-Site Scripting (XSS) - taking untrusted data and sending it without input validation
- A8 - Insecure Deserialization - improperly de-serializing data
- A9 - Using Components with Known Vulnerabilities - libraries and frameworks that have known security holes
- A10 - Insufficient Logging and Monitoring - not having enough logging to detect attacks

***WebGoat - project maintained by OWASP which is an insecure web application meant to be tested

Web Server Attack Methodology

- Information Gathering - Internet searches, whois, reviewing robots.txt
- Web Server Footprinting - banner grabbing
 - Tools
 - ❖ Netcraft
 - ❖ HTTPRecon
 - ❖ ID Serve
 - ❖ HTTPPrintnmap

- ❖ nmap --script http-trace -p80 localhost (detects vulnerable TRACE method)
- ❖ nmap --script http-google-email (lists email addresses)
- ❖ nmap --script hostmap-* (discovers virtual hosts on the IP address you are trying to footprint; * is replaced by online db such as IP2Hosts)
- ❖ nmap --script http-enum -p80 (enumerates common web apps)
- ❖ nmap -p80 --script http-robots.txt (grabs the robots.txt file)
- Website Mirroring - brings the site to your own machine to examine structure, etc.
 - Tools:
 - ❖ Wget
 - ❖ BlackWidow
 - ❖ HTTrack
 - ❖ WebCopier Pro
 - ❖ Web Ripper
 - ❖ SurfOffline
- Vulnerability Scanning - scans web server for vulnerabilities
 - Tools:
 - ❖ Nessus
 - ❖ Nikto - specifically suited for web servers; still very noisy like Nessus
- Session Hijacking
- Web Server Password Cracking

Web Server Architecture

- Most Popular Servers - Apache, IIS and Nginx
- Apache runs configurations as a part of a module within special files (http.conf, etc.)
- IIS runs all applications in the context of LOCAL_SYSTEM. IIS 5 had a ton of bugs - easy to get into

- N-Tier Architecture - distributes processes across multiple servers; normally as three-tier:
- Presentation (web), logic (application) and data (database)
- Error Reporting - should not be showing errors in production; easy to glean information
- HTML - markup language used to display web pages
- HTTP Request Methods
 - GET - retrieves whatever information is in the URL; sending data is done in
 - URL o HEAD - identical to get except for no body return
 - POST - sends data via body - data not shown in URL or in history
 - PUT – requests data be stored at the URL
 - DELETE - requests origin server delete resource
 - TRACE - requests application layer loopback of message
 - CONNECT - reserved for use with proxy
 - Both POST and GET can be manipulated by a web proxy
- HTTP Error Messages
 - 1xx: Informational - request received, continuing
 - 2xx: Success - action received, understood and accepted
 - 3xx: Redirection - further action must be taken
 - 4xx: Client Error - request contains bad syntax or cannot be fulfilled
 - 5xx: Server Error - server failed to fulfill an apparently valid request

Web Server Attacks

- DNS Amplification - uses recursive DNS to DoS a target; amplifies DNS answers to target until it can't do anything
- Directory Transversal (../ or dot-dot-slash) - requests file that should not be accessible from web server o Example: <http://www.example.com/../../../../etc/password>
 - Can use unicode to possibly evade IDS - %2e for dot and %5c for slash
- Parameter Tampering (URL Tampering) - manipulating parameters within URL to achieve escalation or other changes
- Hidden Field Tampering - modifying hidden form fields producing unintended results
- Web Cache Poisoning - replacing the cache on a box with a malicious version of it
- WFETCH - Microsoft tool that allows you to craft HTTP requests to see response data
- Misconfiguration Attack - same as before - improper configuration of a web server
- Password Attack - attempting to crack passwords related to web resources
- Connection String Parameter Pollution - injection attack that uses semicolons to take advantage of databases that use this separation method
- Web Defacement - simply modifying a web page to say something else
- Tools
 - Brutus - brute force web passwords of HTTP
 - Hydra - network login cracker
 - Metasploit
 - Basic working is Libraries use Interfaces and Modules to send attacks to services
 - Exploits hold the actual exploit
 - Payload contains the arbitrary code if exploit is successful
 - Auxiliary used for one-off actions (like a scan)

- NOPS used for buffer-overflow type operations
- Shellshock - causes Bash to unintentionally execute commands when commands are concatenated on the end of function definitions

Web Application Attacks

- Most often hacked before of inherent weaknesses built into the program
- The first step is to identify entry points (POST data, URL parameters, cookies, headers, etc.)
- Tools for Identifying Entry Points
 - WebScarab
 - HTTPPrint
 - BurpSuite
- Web 2.0 - dynamic applications; have a larger attack surface due to simultaneous communication
- File Injection - an attacker injects a pointer in a web form to an exploit hosted elsewhere
- Command Injection - attacker gains shell access using Java or similar
- LDAP Injection - exploits applications that construct LDAP statements o Format for LDAP injection includes)(&)
- SOAP Injection - inject query strings to bypass authentication o SOAP uses XML to format information o Messages are "one way" in nature
- Buffer Overflow (Smashing the stack) - attempts to write data into the application's buffer area to overwrite adjacent memory, execute code or crash a system

- Inputs more data than the buffer is allowed ○ Includes stack, heap, NOP sleds and more
 - Canary's systems can monitor these - if they are changed, they indicate a buffer overflow has occurred; placed between buffer and control data
- XSS (Cross-site scripting) - inputting JavaScript into a web form that alters what the page does
 - Can also be passed via URL (`http://IPADDRESS/";!--"=&{()}`)
 - It can be malicious by accessing cookies and sending them to a remote host
 - Can be mitigated by setting HttpOnly flag for cookies
- Stored XSS - stores the XSS in a forum or like for multiple people to access. Stored attacks are those where the injected script is permanently stored on the target servers, such as in a database, in a message forum, visitor log, comment field, etc. The victim then retrieves the malicious script from the server when it requests the stored information. Stored XSS is also sometimes referred to as Persistent or Type-II XSS
- Cross-Site Request Forgery (CSRF) - forces an end user to execute unwanted actions on an app they're already authenticated on ○ Inherits identity and privileges of victim to perform an undesired function on victim's behalf
 - Captures the session and sends a request based off the logged in user's credentials
 - Can be mitigated by sending random challenge tokens
- Session Fixation - an attacker logs into a legitimate site and pulls a session ID; sends link with session ID to victim. Once victim logs in, an attacker can now log in and run with user's credentials
- Cookies - small text-based files stored that contain information like preferences, session details or shopping cart contents

- Can be manipulated to change functionality (e.g. changing cooking that says "ADMIN=no" to "yes")
- Sometimes, but rarely, can also contain passwords
- SQL Injection - injecting SQL commands into input fields to produce output
 - Data Handling - Definition (DDL), Manipulation (DML) and control (DCL)
 - Example – input "' OR 1 = 1 --" into a login field - basically tells the server if 1 = 1 (always true) to allow the login.
 - Double dash (--) tells the server to ignore the rest of the query (in this example, the password check)
 - Basic test to see if SQL injection is possible is just inserting a single quote (')
 - ❖ Fuzzing - inputting random data into a target to see what will happen
 - ❖ Tautology - using always true statements to test SQL (e.g. 1=1)
 - In-band SQL injection - uses same communication channel to perform attack
 - ❖ Usually is when data pulled can fit into data exported (where data goes to a web table)
 - ❖ Best for using UNION queries
 - Out-of-band SQL injection - uses different communication channels (e.g. export results to file on web server)
 - Blind/inferential - error messages and screen returns don't occur; usually to guess whether command work or use timing to know
 - Tools:
 - ❖ Sqlmap
 - ❖ sqlninja
 - ❖ Havij
 - ❖ SQLBrute

- ❖ Pangolin
- ❖ SQLExec
- ❖ Absinthe
- ❖ BobCat

- HTTP Response Splitting - adds header response data to an input field so server splits the response
 - o Can be used to redirect a user to a malicious site
 - o Is not an attack in and of itself - must be combined with another attack
- Countermeasures - input scrubbing for injections, SQL parameterization for SQL injection, keeping patched servers, turning off unnecessary services, ports and protocols

9 Wireless Network Hacking

Number of Questions - 8

Sub Domain/Description

- Wireless Concepts
- Wireless Encryption
- Wireless Threats
- Wireless Hacking Methodology
- Wireless Hacking Tools
- Bluetooth Hacking
- Wireless Attack Countermeasures
- Wireless Security Tools

Wireless Basics

- 802.11 Series - defines the standards for wireless networks
- 802.15.1 - Bluetooth
- 802.15.4 - Zigbee - low power, low data rate, proximity ad-hoc networks
- 802.16 - WiMAX - broadband wireless metropolitan area networks

Amendments	Frequency (GHz)	Modulation	Speed (Mbps)	Range (Meters)
802.11 (Wi-Fi)	2.4	DSSS, FHSS	1, 2	20 – 100
802.11a	5	OFDM	6, 9, 12, 18, 24, 36, 48, 54	35 – 100
	3.7			5000
802.11ax	2.4 to 5	1024-QAM	2400	240
802.11b	2.4	DSSS	1, 2, 5.5, 11	35 – 140
802.11be	2.4, 5, 6	QAM	3000	120
802.11d	It is an enhancement to 802.11a and 802.11b that enables global portability by allowing variations in frequencies, power levels, and bandwidth			
802.11e	It provides guidance for prioritization of data, voice, and video transmissions enabling QoS			
802.11g	2.4	OFDM	6, 9, 12, 18, 24, 36, 48, 54	38 – 140
802.11i	A standard for wireless local area networks (WLANs) that provides improved encryption for networks that use 802.11a, 802.11b, and 802.11g standards; defines WPA2-Enterprise/WPA2-Personal for Wi-Fi			
802.11n	2.4, 5	MIMO-OFDM	54 – 600	70 – 250
802.15.1 (Bluetooth)	2.4	GFSK, $\pi/4$ -DPSK, 8DPSK	25 – 50	10 – 240
802.15.4 (ZigBee)	0.868, 0.915, 2.4	O-QPSK, GFSK, BPSK	0.02, 0.04, 0.25	1 – 100
802.16 (WiMAX)	2 – 11	SOFDMA	34 – 1000	1609.34 - 9656.06 (1-6 miles)

- Orthogonal Frequency-Division Multiplexing (OFDM) - carries waves in various channels
- Direct-Sequence Spread Spectrum (DSSS) - combines all available waveforms into a single purpose
- Basic Service Set (BSS) - communication between a single AP and its clients
- Basic Service Set Identifier (BSSID) - MAC address of the wireless access point
- Spectrum Analyzer - verifies wireless quality, detects rogue access points and detects attacks
- Directional antenna - signals in one direction; Yagi antenna is a type
- Omnidirectional antenna - signals in all directions
- Parabolic grid antenna - based on principle of a satellite dish but it does not have a solid backing. They can pick up Wi-Fi signals ten miles or more
- Yagi antenna - unidirectional antenna used for 10MHz to VHF and UHF
- Dipole antenna - Bidirectional antenna used to support client connections rather than site to site applications

- Reflector antenna - Reflector antennas are used to concentrate EM energy which is radiated or received at a focal point
- Service Set Identifier (SSID) - a text word (≤ 32 char) that identifies network; provides no security
- Three Types of Authentication
 - Open System - no authentication
 - Shared Key
- Authentication - authentication through a shared key (password)
 - Centralized Authentication - authentication through something like RADIUS
- Association is the act of connecting; authentication is the act of identifying the client

Wireless Encryption

- Wired Equivalent Privacy (WEP)
 - Doesn't effectively encrypt anything
 - Uses RC4 for encryption
 - Original intent was to give wireless the same level of protection of an Ethernet hub
 - Initialization Vector (IV) - used to calculate a 32 bit integrity check value
 - (ICV)
 - ❖ IVs are generally small and are frequently reused
 - ❖ Sent in clear text as a part of the header
 - ❖ This combined with RC4 makes it easy to decrypt the WEP key
 - ❖ An attacker can send disassociate requests to the AP to generate a lot of these
- Wi-Fi Protected Access (WPA or WPA2)
 - WPA uses TKIP with a 128-bit key
 - WPA changes the key every 10,000 packets

- WPA transfers keys back and forth during an Extensible Authentication Protocol (EAP)
- WPA2 Enterprise - can tie an EAP or RADIUS server into the authentication
- WPA2 Personal - uses a pre-shared key to authenticate
- WPA2 uses AES for encryption
- WPA2 ensures FIPS 140-2 compliance
- WPA2 uses CCMP instead of TKIP
- Message Integrity Codes (MIC) – hashes for CCMP to protect integrity
- Cipher Block Chaining Message Authentication Code (CBC-MAC) - integrity process of WPA2

Encryption	Attributes				
	Encryption Algorithm	IV Size	Encryption Key Length	Key Management	Integrity Check Mechanism
WEP	RC4	24-bits	40/104-bits	None	CRC-32
WPA	RC4, TKIP	48-bits	128-bits	4-way handshake	Michael algorithm and CRC-32
WPA2	AES-CCMP	48-bits	128-bits	4-way handshake	CBC-MAC
WPA3	AES-GCMP 256	Arbitrary length 1 - 2^{64}	192-bits	ECDH and ECDSA	BIP-GMAC-256

Wireless Hacking

- Access Control Attacks - Evading WLAN access control measures such as AP MAC filtering and Wi-Fi port access
- Integrity Attacks - Send forged control, management or data frames over a wireless network to misdirect the wireless
- Confidentiality Attacks - Intercept confidential information sends over wireless associations

Access Control Attacks

- Wireless access control attacks aim to penetrate a network by **evading WLAN access control measures**, such as AP MAC filters and Wi-Fi port access controls
- MAC Spoofing
- AP Misconfiguration
- Ad Hoc Associations
- Promiscuous Client
- Client Mis-association
- Unauthorized Association

Integrity Attacks

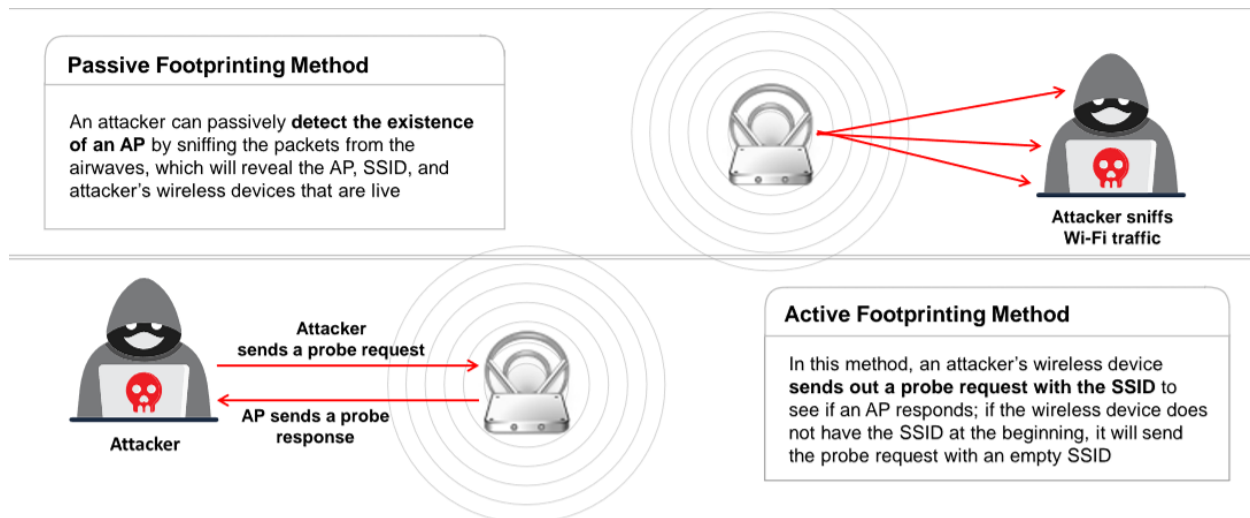
- In integrity attacks, attackers **send forged control, management, or data frames over a wireless network** to misdirect the wireless devices to perform another type of attacks (e.g., DoS)
- Data Frame Injection
- WEP Injection
- Bit-Flipping Attacks
- Extensible AP Replay
- Data Replay
- Initialization Vector Replay Attacks
- RADIUS Replay
- Wireless Network Viruses

Confidentiality Attacks

- These attacks attempt to **intercept confidential information sent over wireless associations**, regardless of whether they were sent in clear text or encrypted by Wi-Fi protocols
- Eavesdropping
- Traffic Analysis
- Cracking WEP Key
- Evil Twin AP
- Honeypot AP
- Session Hijacking
- Masquerading
- Man-in-the-Middle Attack

Network Discovery

- Wardriving, warflying, warwalking, etc.
 - Tools such as WiFiExplorer, WiFiFoFum, OpenSignalMaps, WiFinder o WIGLE - map for wireless networks
 - NetStumbler - tool to find networks
 - Kismet - wireless packet analyzer/sniffer that can be used for discovery
- NetSurveyor - tool for Windows that does similar features to NetStumbler and WiFi Adapter
- AirPcap is mentioned for Windows, but isn't made anymore
 - pcap – driver library for Windows
 - libpcap - drivery library for Linux



Wireless Attacks

- Rogue Access Point - places an access point controlled by an attacker
- Evil Twin - a rogue AP with a SSID similar to the name of a popular network
 - Also known as a mis-association attack
- Honeypot - faking a well-known hotspot with a rogue AP
- Ad Hoc Connection Attack - connecting directly to another phone via ad-hoc network
 - Not very successful as the other user has to accept connection
- DoS Attack - either sends de-auth packets to the AP or jam the wireless signal
 - With a de-auth, you can have the users connect to your AP instead if it has the same name
- Jammers are very dangerous as they are illegal
- MAC Filter - only allows certain MAC addresses on a network
 - Easily broken because you can sniff out MAC addresses already connected and spoof it

Wireless Sniffing

- Very similar to sniffing a wired network
- Tools:
 - Kismet
 - NetStumbler
 - OmniPeek - provides data like Wireshark in addition to network activity and monitoring
 - AirMagnet WiFi Analyzer Pro - sniffer, traffic analyzer and network-auditing suite
 - WiFi Pilot

Airbase-ng	Captures WPA/WPA2 handshake and can act as an ad-hoc AP	Aireplay-ng	Effective for gathering WEP IVs and WPA handshakes
Aircrack-ng	De facto WEP and WPA/WPA2-PSK cracking tool	Airmon-ng	Used to enable monitor mode on wireless interfaces from managed mode and vice versa
Airdecap-ng	Decrypts WEP/WPA/WPA2 and can be used to strip the wireless headers from Wi-Fi packets	Airodump-ng	Used to capture packets of raw 802.11 frames and collect WEP IVs
Airdrop-ng	Used for targeted, rule-based de-authentication of users	Airolib-ng	Stores and manages ESSID and password lists used in WPA/WPA2 cracking https://www.aircrack-ng.org

